

Gründliche Zusammenfassung der Datenschutz-Folien

Thema für Thema — basierend auf Einheit 1–3 der Vorlesung IT-Security / Datenschutz. Jedes Thema mit genauer Fundstelle in den Folien und DSGVO-Bezügen.

1. Einführung, Zweck und Einordnung der DSGVO

1.1 DSGVO als zentraler Datenschutzrechtsakt

Die DSGVO wird als zentraler Datenschutzrechtsakt dargestellt und gilt seit 25.05.2018. Der in den Folien genannte Ausgangspunkt ist Art. 1 DSGVO: Die DSGVO verfolgt zwei Hauptziele, nämlich den Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten und zugleich die Sicherstellung des freien Verkehrs personenbezogener Daten in der Union. Die Folien beschreiben das als Ausgleich diverser Interessen und Grundrechte. [E1/F4]

Bezug zur DSGVO: Art. 1 Abs. 1 DSGVO enthält Vorschriften zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten und zum freien Datenverkehr. Art. 1 Abs. 2 DSGVO schützt die Grundrechte und Grundfreiheiten natürlicher Personen, besonders das Recht auf Schutz personenbezogener Daten. Art. 1 Abs. 3 DSGVO stellt klar, dass der freie Verkehr personenbezogener Daten in der Union aus Datenschutzgründen nicht eingeschränkt oder verboten werden darf.

1.3 Stufenbau der EU-Rechtsordnung

Die Folien ordnen Datenschutz im EU-Recht ein. Auf der obersten Ebene steht Art. 8 Abs. 1 der Charta der Grundrechte der EU (GRC) als Primärrecht: Jede Person hat ein Grundrecht auf Schutz personenbezogener Daten. Darunter steht die DSGVO als Sekundärrecht, also eine Verordnung von Rat und Europäischem Parlament mit allgemeinen Vorgaben. Darunter folgen delegierte und Durchführungsrechtsakte als Tertiärrecht, mit präzisierenden Regeln der Europäischen Kommission, teils mit Mitwirkung des Europäischen Datenschutzausschusses. Zusätzlich gibt es Leitlinien des EDSA, die grundsätzlich unverbindlich sind, aber große praktische Bedeutung für die Auslegung der DSGVO und des Tertiärrechts haben. [E1/F5]

Bezug zur DSGVO: Die DSGVO selbst verweist in den Erwägungsgründen auf das Grundrecht aus Art. 8 Abs. 1 GRC und Art. 16 Abs. 1 AEUV. In Erwägungsgrund 1 DSGVO wird der Schutz personenbezogener Daten ausdrücklich als Grundrecht bezeichnet.

1.4 Harmonisierung und nationale Unterschiede

Die Folien betonen, dass mit der DSGVO eine Vollharmonisierung angestrebt wird. Trotzdem gibt es weiterhin 27 nationale Datenschutzgesetze, weil die DSGVO Öffnungsklauseln enthält, die nationale Unterschiede zulassen. Als Beispiel nennen die Folien unterschiedliche Altersgrenzen für rechtswirksame Einwilligungen. Deshalb muss in Österreich neben der DSGVO auch das österreichische Datenschutzgesetz (DSG) berücksichtigt werden. Ebenfalls relevant ist das TKG 2021, das auf der ePrivacy-Richtlinie basiert, insbesondere für elektronische Kommunikation, Direktwerbung, Spam und Cold Calling. Zum Verhältnis zum EU-Recht wird der Anwendungsvorrang des EU-Rechts genannt. [E1/F6]

Bezug zur DSGVO: Erwägungsgrund 10 DSGVO erklärt das Ziel eines gleichmäßigen und hohen Datenschutzniveaus, lässt den Mitgliedstaaten aber in bestimmten Bereichen Spielraum für genauere nationale Vorschriften. Genau diesen Spielraum greifen die Folien mit den Öffnungsklauseln auf.

1.5 Relevanz und Sanktionen

Die Folien erklären die praktische Relevanz der DSGVO damit, dass seit Inkrafttreten die Verantwortlichkeit beim Datenverarbeiter bzw. Verantwortlichen liegt. Gemeint ist: Wer als juristische oder natürliche Person über Datenverarbeitungen entscheidet, muss die Zulässigkeit sicherstellen. Es gibt Einschränkungen der Zulässigkeit von Datenverarbeitungen, strenge Informations- und Dokumentationspflichten, eine nachträgliche Kontrolle durch die nationale Datenschutzbehörde und eine Strafkompetenz der Datenschutzbehörde. Bei Verstößen drohen hohe Strafen: bis zu 20 Mio. EUR oder 4 % des weltweit erzielten Jahresumsatzes des vorigen Geschäftsjahrs, wobei der höhere Wert gilt. Außerdem wird verwaltungsstrafrechtliche Verantwortlichkeit erwähnt, z. B. relevant bei der Nachbesetzung von Geschäftsführer- und Vorstandsposten in Konzernen. [E1/F7]

Bezug zur DSGVO: Die Höchstbeträge entsprechen Art. 83 Abs. 5 DSGVO. Dort sind für bestimmte schwere Verstöße Geldbußen bis zu 20 Mio. EUR bzw. bei Unternehmen bis zu 4 % des gesamten weltweit erzielten Jahresumsatzes des vorangegangenen Geschäftsjahrs vorgesehen.

2. Anwendungsbereiche von DSGVO und DSG

2.1 Drei Prüfungsebenen

Die Folien stellen die Frage: Wann muss ich DSGVO und DSG beachten? Der Anwendungsbereich wird auf drei Ebenen geprüft: zeitlich, räumlich und sachlich/persönlich. Zeitlich gilt die DSGVO seit 25.05.2018; zu beachten ist immer die jeweils geltende Fassung. Die Folien erwähnen auch, dass eine erste DSGVO-Novelle geplant sei. Beim räumlichen Anwendungsbereich gibt es Unterschiede zwischen DSGVO und DSG; DSGVO und DSG sind aber im sachlichen/persönlichen Bereich großteils ident. [E1/F8-F9]

2.2 Räumlicher Anwendungsbereich der DSGVO

Die Folien bezeichnen die DSGVO als überterritorial, also als Regelwerk mit überterritorialem Ansatz. Die DSGVO gilt erstens bei Verarbeitung durch eine Niederlassung innerhalb der EU. Zweitens kann sie auch bei Niederlassungen außerhalb der EU gelten, wenn Waren oder Dienstleistungen betroffenen Personen in der EU angeboten werden, auch unentgeltlich, oder wenn das Verhalten betroffener Personen in der EU beobachtet wird. [E1/F10]

Bezug zur DSGVO: Das ist Art. 3 DSGVO. Art. 3 Abs. 1 DSGVO erfasst Verarbeitungen im Rahmen der Tätigkeiten einer EU-Niederlassung. Art. 3 Abs. 2 lit. a DSGVO erfasst das Anbieten von Waren oder

Dienstleistungen an Personen in der EU, auch ohne Zahlung. Art. 3 Abs. 2 lit. b DSGVO erfasst das Beobachten des Verhaltens betroffener Personen in der EU.

2.3 Räumlicher Anwendungsbereich des österreichischen DSG

Das österreichische DSG wird in den Folien als regionaler Ansatz dargestellt. Es ist relevant bei Verarbeitung von Daten im Inland, also in Österreich, oder bei Verarbeitung von Daten für Zwecke eines österreichischen Verantwortlichen, also eines in Österreich niedergelassenen Verantwortlichen. [E1/F11]

2.4 Beispiele für Plattformbetreiber

Die Folien geben Beispiele zur Einordnung: Plattformbetreiber mit Sitz oder Niederlassung innerhalb der EU, z. B. Facebook Irland, Google Irland oder Xing Deutschland, unterliegen der DSGVO und dem nationalen Datenschutzgesetz des Sitzstaats. Ein Plattformbetreiber mit Sitz in einem Drittstaat, z. B. Twitter USA, kann der DSGVO und abhängig von der Ausrichtung der Geschäftstätigkeit gegebenenfalls mehreren nationalen Datenschutzgesetzen unterliegen. Ein Plattformbetreiber mit Sitz in Österreich unterliegt der DSGVO und dem österreichischen DSG. [E1/F12]

Bezug zur DSGVO: Die Beispiele beruhen auf Art. 3 DSGVO und auf der Abgrenzung zwischen EUNiederlassung, Drittstaatenbezug und Markttortprinzip.

2.5 Persönlicher und sachlicher Anwendungsbereich

Die Folien nennen ausdrücklich Art. 2 iVm Art. 3 Abs. 1-2 DSGVO. DSGVO und DSG gelten nur für personenbezogene Daten natürlicher Personen. Daten juristischer Personen sind grundsätzlich nicht geschützt. Für Österreich wird erwähnt, dass das Datenschutzgrundrecht und teilweise eine analoge Anwendung der DSGVO berücksichtigt werden können. Spam- und Cold-Calling-Regeln im TKG 2021 bleiben unberührt und gelten auch für juristische Personen. [E1/F13]

Bezug zur DSGVO: Art. 2 Abs. 1 DSGVO regelt den sachlichen Anwendungsbereich für automatisierte Verarbeitung personenbezogener Daten und nichtautomatisierte Verarbeitung, wenn die Daten in einem Dateisystem gespeichert sind oder werden sollen. Erwägungsgrund 14 DSGVO stellt klar, dass der Schutz für natürliche Personen gilt und nicht für juristische Personen, einschließlich Name, Rechtsform oder Kontaktdaten juristischer Personen.

2.6 Haushaltsausnahme

Die Folien nennen als Ausnahme die Haushaltsausnahme: Die DSGVO ist nicht anwendbar bei ausschließlich persönlicher oder familiärer Tätigkeit. Als Grenzbereich nennen die Folien Veröffentlichungen in Gruppen sozialer Netzwerke; dort gebe es keine starren Grenzen, sondern eine Einzelfallabwägung. [E1/F13]

Bezug zur DSGVO: Art. 2 Abs. 2 lit. c DSGVO nimmt Verarbeitungen durch natürliche Personen zur Ausübung ausschließlich persönlicher oder familiärer Tätigkeiten aus. Erwägungsgrund 18 DSGVO nennt als mögliche persönliche/familiäre Tätigkeiten etwa Schriftverkehr, Anschriftenverzeichnisse und Nutzung sozialer Netze im persönlichen Rahmen, stellt aber klar, dass die DSGVO für Anbieter der entsprechenden Verarbeitungsinstrumente gilt.

2.7 Sachlicher Anwendungsbereich: Verarbeitung personenbezogener Daten

Die Folien erklären den sachlichen Anwendungsbereich über zwei Kernbegriffe: Verarbeitung und personenbezogene Daten. Verarbeitung ist jeder mögliche Umgang mit Daten, etwa Erheben, Erfassen, Organisieren, Ordnen, Speichern, Anpassen, Verändern, Auslesen, Abfragen, Verwenden, Offenlegen, Verbreiten, Bereitstellen, Abgleichen, Verknüpfen, Einschränken, Löschen oder Vernichten. Personenbezogene Daten sind alle Informationen, weit zu interpretieren, die sich direkt oder indirekt auf eine identifizierte oder identifizierbare natürliche Person beziehen. Wiedererkennbarkeit ist das maßgebende Kriterium. Als Beispiel wird die bloße dynamische IP-Adresse genannt. [E1/F14]

Bezug zur DSGVO: Die Definition von Verarbeitung steht in Art. 4 Nr. 2 DSGVO. Die Definition personenbezogener Daten steht in Art. 4 Nr. 1 DSGVO. Erwägungsgrund 30 DSGVO erklärt zusätzlich, dass Online-Kennungen wie IP-Adressen und Cookie-Kennungen Spuren hinterlassen können, die zur Profilbildung und Identifizierung genutzt werden können.

2.8 Unterschied DSGVO und DSG bei nicht automatisierter Verarbeitung

Die Folien unterscheiden: Die DSGVO gilt für ganz oder teilweise automatisierte Verarbeitung und für nichtautomatisierte Verarbeitung, wenn diese in einem Dateisystem gespeichert ist oder gespeichert werden soll. Das DSG wird weiter dargestellt: Es erfasst auch nicht automatisierte Verarbeitung, z. B. Papierakten. [E1/F14]

Bezug zur DSGVO: Art. 2 Abs. 1 DSGVO nennt die automatisierte Verarbeitung und nichtautomatisierte Verarbeitung in Dateisystemen. Die weitergehende nationale Darstellung betrifft das österreichische DSG.

3. Rollen und Verantwortlichkeiten

3.1 Grundfrage der Zulässigkeit

Die zentrale praktische Frage lautet laut Folien: Wer verwendet welche Daten von wem zu welchem Zweck? Diese Frage strukturiert die Prüfung: Es muss klar sein, wer

handelt, welche Daten betroffen sind, wessen Daten verarbeitet werden und welchem Zweck die Verarbeitung dient. [E1/F15-F16]

Bezug zur DSGVO: Diese Logik hängt mit mehreren DSGVO-Prüfpunkten zusammen: Art. 4 DSGVO definiert Rollen und Datenbegriffe, Art. 5 Abs. 1 lit. b DSGVO verlangt Zweckbindung, und Art. 6 DSGVO verlangt eine Rechtsgrundlage für die Verarbeitung.

3.2 Betroffene Person

Die betroffene Person ist jene natürliche Person, deren personenbezogene Daten verarbeitet werden. Beispiele in den Folien sind Mitarbeiter und Bewerber eines zukünftigen Arbeitgebers, Kunden, Lieferanten und deren Kontaktpersonen sowie Nutzer von Websites und Social-Media-Plattformen. [E1/F17]

Bezug zur DSGVO: Art. 4 Nr. 1 DSGVO bezeichnet die identifizierte oder identifizierbare natürliche Person als „betroffene Person“.

3.3 Verantwortlicher

Der Verantwortliche ist jeder, der über Zwecke und Mittel der Datenverarbeitung entscheidet. Die Folien formulieren ihn als denjenigen, in dessen Interesse die Verarbeitung erfolgt, also als „Herr der Daten“. Beispiele sind Arbeitgeber hinsichtlich ihrer Mitarbeiter, Vertragspartner hinsichtlich Kunden und Lieferanten,

Betreiber einer Website oder einer Social-Media-Seite. Maßgeblich ist die faktische Entscheidungskompetenz, nicht bloß die formale Bezeichnung. [E1/F17]

Bezug zur DSGVO: Das entspricht Art. 4 Nr. 7 DSGVO. Dort ist Verantwortlicher die natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über Zwecke und Mittel der Verarbeitung entscheidet.

3.4 Auftragsverarbeiter

Auftragsverarbeiter ist jeder, der personenbezogene Daten im Auftrag und auf Weisung des Verantwortlichen verarbeitet und nicht selbst über Zwecke und Art der Verarbeitung entscheidet. Beispiele in den Folien sind IT-Service-Provider, Cloud Provider, Anbieter von Softwarelösungen und Tools, externe Lohnverrechnung oder externe Buchhaltung. [E1/F17]

Bezug zur DSGVO: Das entspricht Art. 4 Nr. 8 DSGVO. Die Pflichten für Auftragsverarbeiter werden später in den Folien mit Art. 28 DSGVO verbunden. [E2/F21-F24]

3.5 Gemeinsame Verantwortlichkeit bei Social Media

Die Folien nennen die EuGH-Rechtsprechung: Betreiber von Facebook-Seiten sind gemeinsam mit dem sozialen Netzwerk verantwortlich, bezogen auf die Datenverarbeitung im Zusammenhang mit Facebook Insights. Der Grund ist, dass Facebook Insight dem Seiteninhaber statistische Auswertungen über Besucher ermöglicht und dadurch Angebot und Aktionen zielgruppengerecht ausgerichtet

werden können. Damit entscheidet der Seiteninhaber jedenfalls mit über Zwecke. Die Folien sagen, dass dies wohl auch für andere soziale Netzwerke gilt. [E1/F18]

Konsequenzen laut Folien: Es ist eine Vereinbarung über gemeinsame Verantwortlichkeit abzuschließen, Social Media ist in das Verzeichnis der Verarbeitungstätigkeiten aufzunehmen, der Seiteninhaber muss Informationspflichten erfüllen, etwa durch eine eigene Social-Media-Datenschutzerklärung, und Betroffenenrechte wahren, insbesondere Recht auf Auskunft und Recht auf Löschung. [E1/F18]

Bezug zur DSGVO: Die gemeinsame Verantwortlichkeit ist in Art. 26 DSGVO geregelt. Danach müssen gemeinsam Verantwortliche in transparenter Form festlegen, wer welche DSGVO-Pflichten erfüllt, insbesondere hinsichtlich Betroffenenrechten und Informationspflichten.

3.6 Beispiel: Arbeitgeber, Arbeitnehmer, externe Buchhaltung

Die Folien zeigen eine Rollenverteilung: Arbeitnehmer sind Betroffene. Der Arbeitgeber entscheidet über Zwecke und Mittel der Verarbeitung und ist daher Verantwortlicher. Die externe Buchhaltung verarbeitet z. B. Name, Geburtsdatum und Gehalt auf Weisung und ist daher Auftragsverarbeiter. [E1/F19]

Bezug zur DSGVO: Diese Abgrenzung stützt sich auf Art. 4 Nr. 7 DSGVO für den Verantwortlichen und Art. 4 Nr. 8 DSGVO für den Auftragsverarbeiter.

4. Datenkategorien: personenbezogen, pseudonym, anonym, sensibel

4.1 Personenbezogene Daten

Die Folien arbeiten mit einem weiten Verständnis personenbezogener Daten. Personenbezogen ist alles, was sich direkt oder indirekt auf eine identifizierte oder identifizierbare natürliche Person bezieht. Entscheidend ist

die Wiedererkennbarkeit. Auch eine dynamische IP-Adresse kann personenbezogen sein. [E1/F14, E1/F20F21]

Bezug zur DSGVO: Art. 4 Nr. 1 DSGVO definiert personenbezogene Daten. Erwägungsgrund 30 DSGVO nennt ausdrücklich Online-Kennungen wie IP-Adressen und Cookie-Kennungen als mögliche Identifizierungsmerkmale.

4.2 Pseudonymisierung

Pseudonymisierung bedeutet laut Folien eine Verarbeitung, bei der personenbezogene Daten ohne zusätzliche Informationen nicht mehr einer spezifischen betroffenen Person zugeordnet werden können. Diese zusätzlichen Informationen müssen gesondert aufbewahrt werden und technischen und organisatorischen Maßnahmen unterliegen, damit keine Zuordnung zu einer identifizierten oder identifizierbaren natürlichen Person erfolgt. Die Folien betonen: Pseudonymisierte Daten bleiben

personenbezogene Daten; es gibt keine generelle Ausnahme und keine allgemeinen Erleichterungen für pseudonyme bzw. pseudonymisierte Daten. [E1/F21]

Bezug zur DSGVO: Das ist Art. 4 Nr. 5 DSGVO. Erwägungsgrund 26 DSGVO stellt klar, dass pseudonymisierte personenbezogene Daten, die durch zusätzliche Informationen einer Person zugeordnet werden könnten, weiterhin als Informationen über eine identifizierbare natürliche Person gelten.

4.3 Anonymisierung

Anonymisierung bedeutet laut Folien, dass Informationen sich nicht auf eine bestimmte oder bestimmbare natürliche Person beziehen oder personenbezogene Daten so anonymisiert sind, dass die betroffene Person nicht oder nicht mehr identifiziert werden kann. Die Folien betonen, dass die Anforderungen sehr hoch sind und in der Praxis schwer zu erreichen. [E1/F21]

Bezug zur DSGVO: Erwägungsgrund 26 DSGVO erklärt, dass Datenschutzgrundsätze nicht für anonyme Informationen gelten, also nicht für Informationen, die sich nicht auf eine identifizierte oder identifizierbare natürliche Person beziehen oder so anonymisiert wurden, dass die Person nicht oder nicht mehr identifiziert werden kann.

4.4 Besondere Kategorien personenbezogener Daten / sensible Daten

Die Folien unterscheiden sensible Daten nach Art. 9 DSGVO und Daten über strafrechtliche Verurteilungen und Straftaten nach Art. 10 DSGVO. Zu sensiblen Daten zählen unter anderem rassische oder ethnische Herkunft, politische, religiöse oder weltanschauliche Meinungen, Gewerkschaftszugehörigkeit, Gesundheitsdaten sowie genetische und biometrische Daten. [E1/F22]

Bezug zur DSGVO: Art. 9 Abs. 1 DSGVO enthält das Verarbeitungsverbot besonderer Kategorien personenbezogener Daten, u. a. Daten zur rassischen/ethnischen Herkunft, politischen Meinungen, religiösen oder weltanschaulichen Überzeugungen, Gewerkschaftszugehörigkeit, genetische Daten, biometrische Daten zur eindeutigen Identifizierung, Gesundheitsdaten oder Daten zum Sexualleben bzw. zur sexuellen Orientierung. Art. 10 DSGVO regelt Daten über strafrechtliche Verurteilungen und Straftaten.

4.5 Gesundheitsdaten

Die Folien nennen Gesundheitsdaten ausdrücklich als sensible Daten. Die Definition wird als breit beschrieben: Sie betrifft körperliche oder geistige Gesundheit, vergangene und aktuelle Zustände sowie Prognosen. Für

Gesundheitsdaten gilt ein strengeres Schutzregime. [E1/F22]

Bezug zur DSGVO: Art. 4 Nr. 15 DSGVO definiert Gesundheitsdaten als personenbezogene Daten, die sich auf die körperliche oder geistige Gesundheit einer natürlichen Person beziehen und aus denen Informationen über deren Gesundheitszustand hervorgehen. Erwägungsgrund 35 DSGVO erläutert dies weiter und umfasst frühere, gegenwärtige und künftige Gesundheitszustände.

5. Grundprinzipien und Rechtmäßigkeit der Verarbeitung

5.1 Grundprinzipien nach Art. 5 DSGVO

Die Folien listen die Grundprinzipien aus Art. 5 DSGVO auf: Rechtmäßigkeit, Verarbeitung nach Treu und Glauben und Transparenz; Zweckbindung; Datenminimierung; Richtigkeit; Speicherbegrenzung; Integrität und Vertraulichkeit. Dazu kommt, dass die Zulässigkeit über eine taxative Liste von Erlaubnistatbeständen geprüft wird. [E1/F23-F24]

Bezug zur DSGVO: Art. 5 Abs. 1 DSGVO enthält diese Grundsätze. Art. 5 Abs. 2 DSGVO enthält die Rechenschaftspflicht: Der Verantwortliche ist für die Einhaltung verantwortlich und muss sie nachweisen können.

5.2 Zweckbindung

Die Folien betonen den strengen Zweckbindungsgrundsatz: Jede Datenanwendung ist zweckgebunden. Daten dürfen grundsätzlich nur für festgelegte, eindeutige und legitime Zwecke verarbeitet werden. Leitfragen sind: Was soll durch die Datenverarbeitung erreicht werden? Was ist das Ziel? Warum werden Daten überhaupt genutzt? [E1/F25]

Bezug zur DSGVO: Art. 5 Abs. 1 lit. b DSGVO verlangt, dass personenbezogene Daten für festgelegte, eindeutige und legitime Zwecke erhoben werden und nicht in einer damit unvereinbaren Weise weiterverarbeitet werden dürfen. Für die Rechtmäßigkeit braucht es zusätzlich eine Grundlage nach Art. 6 DSGVO.

5.3 Rechtsgrundlagen nach Art. 6 DSGVO für nicht sensible Daten

Die Folien nennen als Rechtsgrundlagen insbesondere Vertragserfüllung, berechnigte Interessen, gesetzliche Verpflichtung und Einwilligung. Sie beziehen dies auf nicht sensible personenbezogene Daten, z. B. Name, Adresse, Geburtsdatum, Geschlecht, Ausbildung, Gehaltsdaten, Fotos, IP-Adresse oder Nutzungsverhalten. [E1/F26-F27]

Bezug zur DSGVO: Art. 6 Abs. 1 DSGVO enthält sechs Rechtsgrundlagen: Einwilligung, Vertragserfüllung/vorvertragliche Maßnahmen, rechtliche Verpflichtung, lebenswichtige Interessen, öffentliche Aufgabe/öffentliche Gewalt und berechnigte Interessen. In den Folien werden vor allem Art. 6 Abs. 1 lit. a, b, c und f DSGVO hervorgehoben.

5.4 Vertragserfüllung

Die Vertragserfüllung ist laut Folien relevant im Verhältnis zu Mitarbeitern sowie Kunden und Lieferanten, etwa für Lohnverrechnung oder gewöhnliche Geschäftsabwicklung. Wichtig ist: Abgedeckt sind nur die unbedingt erforderlichen Daten. [E1/F27]

Bezug zur DSGVO: Art. 6 Abs. 1 lit. b DSGVO erlaubt Verarbeitung, wenn sie für die Erfüllung eines Vertrags mit der betroffenen Person oder für vorvertragliche Maßnahmen auf Anfrage der betroffenen Person erforderlich ist. Die Folien betonen daher richtig die Erforderlichkeit.

5.5 Gesetzliche Verpflichtung

Die Verarbeitung aufgrund gesetzlicher Verpflichtung ist laut Folien praktisch vor allem bei Mitarbeiterdatenverarbeitung relevant, z. B. Meldepflichten an Gesundheitskasse bzw. Finanzamt, sowie bei Kunden- und Lieferantendaten, etwa gesetzliche Aufbewahrungspflichten, in der Praxis häufig sieben Jahre. [E1/F27]

Bezug zur DSGVO: Art. 6 Abs. 1 lit. c DSGVO erlaubt Verarbeitung, wenn sie zur Erfüllung einer rechtlichen Verpflichtung erforderlich ist. Art. 6 Abs. 3 DSGVO verlangt eine Grundlage im Unionsrecht oder im Recht des Mitgliedstaats.

5.6 Berechtigte Interessen

Die Folien beschreiben die berechtigten Interessen als auslegungsbedürftig und unsichere Rechtsgrundlage, weil es keine konkreten Parameter gibt und eine Abwägung mit grundrechtlich geschützten Positionen nötig ist. Direktmarketing kann laut Folien von berechtigten Interessen gedeckt sein, aber die Bestimmungen des TKG 2021 zu Spam und Cold Calling gehen als *lex specialis* vor; bei elektronischer Direktwerbung ist daher oft Einwilligung erforderlich. Zudem besteht ein jederzeitiges Widerspruchsrecht. Betrugsverhinderung wird ebenfalls genannt. Konzernübermittlungen zu internen Verwaltungszwecken können nach Erwägungsgrund 48 ein berechtigtes Interesse sein; die Folien betonen aber: Es gibt kein allgemeines Konzernprivileg. [E1/F28]

Bezug zur DSGVO: Art. 6 Abs. 1 lit. f DSGVO erlaubt Verarbeitung zur Wahrung berechtigter Interessen, sofern Interessen oder Grundrechte der betroffenen Person nicht überwiegen, besonders bei Kindern. Erwägungsgrund 47 DSGVO nennt Direktwerbung und Betrugsverhinderung als mögliche berechtigten Interessen. Erwägungsgrund 48 DSGVO nennt konzerninterne Verwaltungszwecke als mögliches berechtigtes Interesse, schafft aber kein pauschales Konzernprivileg.

5.7 Abwägung bei legitimen Interessen

Die Folien zeigen eine einzelfallbezogene Abwägung: Ein niedriger Datenumfang spricht eher für die Verarbeitung, ein hoher Datenumfang eher dagegen. Geringe potenzielle Risiken für Betroffene sprechen eher dafür, hohe Risiken eher dagegen. Erwartbare Verarbeitung ist günstiger als überraschende Verarbeitung. Kein besonderes Schutzbedürfnis spricht eher dafür; ein besonderes Schutzbedürfnis, z. B. bei Kindern, spricht eher gegen die Verarbeitung. [E1/F29]

Bezug zur DSGVO: Diese Abwägung folgt aus Art. 6 Abs. 1 lit. f DSGVO. Kinder werden dort ausdrücklich als besonders schutzwürdig erwähnt.

5.8 Rechtsgrundlagen für sensible Daten nach Art. 9 DSGVO

Die Folien stellen bei sensiblen Daten strengere Voraussetzungen dar. Für Daten nach Art. 9 DSGVO reichen allgemeine Rechtsgrundlagen nach Art. 6 nicht aus; es braucht zusätzlich eine Ausnahme vom Verarbeitungsverbot. Genannt werden ausdrückliche Einwilligung, Erfüllung arbeits- und sozialrechtlicher Pflichten und Erforderlichkeit zur Durchsetzung von Rechtsansprüchen. [E1/F26]

Bezug zur DSGVO: Art. 9 Abs. 1 DSGVO verbietet grundsätzlich die Verarbeitung besonderer Kategorien personenbezogener Daten. Art. 9 Abs. 2 DSGVO enthält Ausnahmen, etwa ausdrückliche Einwilligung nach lit. a, Arbeits- und Sozialrecht nach lit. b oder Geltendmachung, Ausübung oder Verteidigung von Rechtsansprüchen nach lit. f.

6. Einwilligung

6.1 Anforderungen an die Einwilligung

Die Folien nennen als Anforderungen: Einwilligung muss freiwillig, unmissverständlich, für den bestimmten Fall und in informierter Weise erfolgen. Sie muss vor der Verwendung der Daten eingeholt werden. Es gibt keine bestimmte Formvorschrift. Schweigen und voraktivierte Checkboxes sind ungültig. Die Einwilligung muss nachweisbar sein. Sie ist jederzeit ohne Grund mit Wirkung für die Zukunft widerrufbar; der Widerruf muss so einfach sein wie die Erteilung und unterliegt keiner Formpflicht. [E1/F30]

Bezug zur DSGVO: Art. 4 Nr. 11 DSGVO definiert Einwilligung als freiwillige, bestimmte, informierte und unmissverständliche Willensbekundung. Art. 7 DSGVO regelt Nachweisbarkeit, Bedingungen und Widerruf. Erwägungsgrund 32 DSGVO stellt klar, dass Stillschweigen, bereits angekreuzte Kästchen oder Untätigkeit keine Einwilligung darstellen.

6.2 Inhalt einer Zustimmungserklärung

Die Folien verlangen für eine Zustimmungserklärung: Name und Adresse des Verantwortlichen, verwendete Datenarten detailliert und taxativ, detaillierte Zweckangabe, Name und Adresse etwaiger Empfänger samt Übermittlungszweck und Hinweis auf jederzeitige Widerrufbarkeit. Alle Informationen müssen direkt aus der Einwilligungserklärung oder aus dem unmittelbaren Kontext hervorgehen. [E1/F31]

Bezug zur DSGVO: Diese Anforderungen folgen aus Art. 7 DSGVO und dem Transparenzgebot nach Art. 5 Abs. 1 lit. a DSGVO. Erwägungsgrund 42 DSGVO verlangt insbesondere, dass die betroffene Person mindestens weiß, wer der Verantwortliche ist und für welche Zwecke ihre Daten verarbeitet werden.

6.3 Praxistipps und typische Fehler bei Einwilligungen

Die Folien empfehlen eine Extra-Checkbox für Einwilligungen. Einwilligungen in AGB, Datenschutzerklärung oder Dienstvertrag werden als unzulässig dargestellt, weil die Freiwilligkeit fehlt oder zweifelhaft ist. Die Folien warnen außerdem davor, eine bloße Kenntnisnahme oder Bestätigung von Datenschutzhinweisen einzuholen; dies könne wegen gefestigter Rechtsprechung problematisch sein und im Worst Case als Einwilligung interpretiert werden. Genannt werden Risiken durch Klagen von Verbraucherschutzverbänden wie VKI oder AK und konsumentenschutzrechtliche Maßstäbe, etwa Änderungsrecht versus Aktualisierungspflicht. [E1/F31]

Bezug zur DSGVO: Art. 7 Abs. 4 DSGVO betrifft die Freiwilligkeit bei Kopplung mit Vertragserfüllung. Erwägungsgrund 43 DSGVO erklärt, dass Einwilligung nicht freiwillig ist,

wenn Vertragserfüllung von einer nicht erforderlichen Einwilligung abhängig gemacht wird oder verschiedene Verarbeitungsvorgänge nicht getrennt akzeptiert werden können.

6.4 Beispiele für keine Einwilligung

Die Folien nennen ausdrücklich Beispiele, die keine Einwilligung im Sinne der DSGVO sind: bloße Angabe einer Kontaktadresse, etwa für Kauf oder Registrierung; Social-Media-Freundschaft; Klick auf „Gefällt mir“ oder

ähnliche Schaltflächen; Tell-a-Friend-Funktion; und nach einer Entscheidung des BVwG vom 16.08.2023, W157 2262141-1, auch die Übergabe einer Visitenkarte auf einer Konferenz, auf der handschriftlich eine E-Mail-Adresse notiert ist. Schweigen, voraktivierte Kontrollkästchen oder sonstige Inaktivität sind ungültig. Die Folien ergänzen, dass wahrscheinlich für jeden Zweck eine gesonderte Einwilligung erforderlich ist und dass die Einwilligung aktiv und vor dem Erhalt der ersten Werbung gegeben werden muss. [E1/F32]

Bezug zur DSGVO: Erwägungsgrund 32 DSGVO verlangt eine eindeutige bestätigende Handlung und sagt ausdrücklich, dass Stillschweigen, vorangekreuzte Kästchen oder Untätigkeit keine Einwilligung sind. Wenn mehrere Zwecke bestehen, soll nach Erwägungsgrund 32 für alle Zwecke eine Einwilligung gegeben werden; die Folien interpretieren dies praktisch als gesonderte Einwilligung pro Zweck.

7. Weitergabe personenbezogener Daten an Dritte

7.1 Weitergabe als Offenlegung

Die Folien definieren Weitergabe als jede Offenlegung personenbezogener Daten an einen externen Empfänger. Es gilt strenge Zweckbindung und kein allgemeines Konzernprivileg. Beispiele sind Rechtsanwälte, ein CRM-Tool im Konzern oder ein IT-Dienstleister. [E1/F33]

Bezug zur DSGVO: Offenlegung ist Teil der Definition von Verarbeitung in Art. 4 Nr. 2 DSGVO. Zweckbindung folgt aus Art. 5 Abs. 1 lit. b DSGVO. Konzernübermittlungen können nur im Einzelfall, z. B. nach Erwägungsgrund 48 DSGVO, gerechtfertigt sein.

7.2 Empfänger als Verantwortlicher oder Auftragsverarbeiter

Die Folien unterscheiden zwei Fälle: Ist der Empfänger selbst Verantwortlicher, verwendet er die Daten für gemeinsame oder eigene Zwecke; dann braucht es eine Rechtsgrundlage für die Weitergabe und gegebenenfalls eine Joint-Controller-Vereinbarung. Ist der Empfänger Auftragsverarbeiter, verwendet er die Daten nur für den Verantwortlichen; dann ist eine Auftragsverarbeitungsvereinbarung erforderlich. [E1/F33]

Bezug zur DSGVO: Verantwortlicher ist Art. 4 Nr. 7 DSGVO, Auftragsverarbeiter Art. 4 Nr. 8 DSGVO, gemeinsame Verantwortlichkeit Art. 26 DSGVO, Auftragsverarbeitung Art. 28 DSGVO.

8. Pflichten der Verantwortlichen unter der DSGVO

8.1 Überblick über Pflichten

Die Folien nennen als Pflichten der Verantwortlichen: Datenschutz-Folgenabschätzung bzw. PIA, Dokumentation von Verarbeitungstätigkeiten, Rechenschaftspflicht und Zusammenarbeit mit der Aufsichtsbehörde, Verträge mit gemeinsam Verantwortlichen und Auftragsverarbeitern, eigene Einheiten, grenzüberschreitender Datenverkehr, Privacy by Design und by Default sowie Bestellung eines Datenschutzbeauftragten. [E2/F2-F4]

Bezug zur DSGVO: Diese Pflichten verteilen sich auf mehrere Artikel: Art. 30 DSGVO für Verzeichnisse, Art. 5 Abs. 2 und Art. 24 DSGVO für Rechenschaft und Verantwortlichkeit, Art. 26 DSGVO für gemeinsame Verantwortliche, Art. 28 DSGVO für Auftragsverarbeitung, Art. 25 DSGVO für Privacy by Design/Default, Art. 35 DSGVO für DSFA/PIA und Art. 37-39 DSGVO für Datenschutzbeauftragte.

9. Dokumentation der Verarbeitungstätigkeiten

9.1 Verzeichnis des Verantwortlichen

Die Folien sagen, dass nahezu jeder Verantwortliche ein Verzeichnis der Verarbeitungstätigkeiten führen muss. Der Mindestinhalt ist vorgegeben. Das Verzeichnis ist schriftlich oder elektronisch zu führen, auf Anfrage der Aufsichtsbehörde vorzulegen und dient zur Prüfung und zum Nachweis der DSGVO-Compliance. [E2/F5] Der in den Folien genannte Mindestinhalt umfasst: Name und Kontaktdaten des Verantwortlichen, Zweck der Verarbeitung, Kategorien der Betroffenen, Daten und Empfänger, Beschreibung geeigneter Garantien bei Übermittlungen in Drittländer, Fristen für Löschung der Daten und Beschreibung der Sicherheitsmaßnahmen. [E2/F5]

Bezug zur DSGVO: Das entspricht Art. 30 Abs. 1 DSGVO. Erwägungsgrund 82 DSGVO erklärt, dass Verantwortliche und Auftragsverarbeiter zum Nachweis der Einhaltung ein Verzeichnis führen und mit der Aufsichtsbehörde zusammenarbeiten sollen.

9.2 Verzeichnis des Auftragsverarbeiters

Auch Auftragsverarbeiter müssen laut Folien ein Verzeichnis erstellen, allerdings mit verkürztem Inhalt. Genannt werden Name und Kontaktdaten des Auftragsverarbeiters und aller Verantwortlichen, Kategorien der Verarbeitungen je Verantwortlichem, Beschreibung geeigneter Garantien bei Drittlandübermittlungen und eine allgemeine Beschreibung der technischen und organisatorischen Sicherheitsmaßnahmen. [E2/F6]

Bezug zur DSGVO: Das entspricht Art. 30 Abs. 2 DSGVO.

9.3 Praktische Erstellung und Aktualisierung

Die Folien empfehlen praktische Schritte: Zuerst feststellen, welche Verarbeitungen es überhaupt gibt. Dann pro Verarbeitung grobe Informationen sammeln, z. B. Zwecke,

Kategorien der Betroffenen und Daten. Danach werden Detailinformationen nach und nach ergänzt, z. B. Verträge mit Empfängern, Löschfristen und Sicherheitsmaßnahmen. Das Verzeichnis muss regelmäßig aktualisiert werden, wenn Verarbeitungen neu sind, geändert wurden oder eingestellt wurden. [E2/F7-F8]

Bezug zur DSGVO: Die Aktualität ergibt sich aus dem Zweck des Art. 30 DSGVO als Nachweis- und Kontrollinstrument und aus der Rechenschaftspflicht nach Art. 5 Abs. 2 DSGVO.

10. Datenschutz-Folgenabschätzung / PIA / DSFA

10.1 Wann ist eine DSFA erforderlich?

Die Folien stellen die Datenschutz-Folgenabschätzung als Pflicht bei Verarbeitungen dar, die voraussichtlich ein hohes Risiko für Betroffene mit sich bringen, insbesondere aufgrund Art, Umfang, Umständen und Zweck der Verarbeitung sowie besonders bei Verwendung neuer Technologien. Dann ist vorab eine DSFA/PIA zu erstellen. [E2/F9-F10] Jedenfalls erforderlich ist eine DSFA laut Folien bei Bewertung auf Basis automatisierter Entscheidungen bzw. Profiling, bei umfangreicher Verarbeitung sensibler Daten oder strafrechtlich relevanter Daten sowie bei systematischer Überwachung öffentlich zugänglicher Bereiche. Die Abgrenzung ist in der Praxis schwierig. Der

EDSA gibt Auslegungshilfen; außerdem gibt es Black Lists und White Lists der Datenschutzbehörden. Bei ähnlichen Verarbeitungen genügt eine PIA. Eine laufende Überprüfung ist erforderlich. Nicht der Datenschutzbeauftragte erstellt die DSFA; er gibt nur Rat, vgl. Art. 35 Abs. 2 DSGVO. [E2/F10]

Bezug zur DSGVO: Art. 35 Abs. 1 DSGVO verlangt eine DSFA, wenn eine Verarbeitung voraussichtlich ein hohes Risiko für Rechte und Freiheiten natürlicher Personen zur Folge hat. Art. 35 Abs. 3 DSGVO nennt insbesondere systematische und umfassende Bewertung persönlicher Aspekte auf Basis automatisierter Verarbeitung einschließlich Profiling, umfangreiche Verarbeitung besonderer Kategorien oder von Strafdaten und systematische umfangreiche Überwachung öffentlich zugänglicher Bereiche. Art. 35 Abs. 2 DSGVO verlangt, dass der Verantwortliche bei Durchführung einer DSFA den Rat des Datenschutzbeauftragten einholt, sofern ein solcher benannt wurde.

10.2 White List der österreichischen Datenschutzbehörde

Die Folien nennen als White List der österreichischen Datenschutzbehörde die DSFA-Ausnahmereverordnung. Diese konzentriert sich nicht auf bestimmte Kategorien von Betroffenen, Daten und Empfängern, sondern beschreibt den Zweck der Datenverarbeitung. Als wichtigste Ausnahmen in der Praxis werden genannt: Kundenmanagement; Rechnungswesen, Logistik und Buchhaltung; Personalverwaltung; Kundenpflege und Marketing für eigene Zwecke; Zugangsverwaltung für EDV-Systeme; Zutrittskontrolle; und Videoüberwachung, sofern nur eigene Räumlichkeiten erfasst werden, öffentliche Bereiche höchstens 0,5 m einbezogen werden, die Aufbewahrungszeit maximal 72 Stunden beträgt und eine ordnungsgemäße Identifizierung erfolgt. [E2/F11]

Bezug zur DSGVO: Die Möglichkeit solcher Listen ergibt sich aus Art. 35 Abs. 5 DSGVO, wonach Aufsichtsbehörden Listen von Verarbeitungsvorgängen veröffentlichen können, für die keine DSFA erforderlich ist.

10.3 Black List der österreichischen Datenschutzbehörde

Die Folien nennen die DSFA-Verordnung als Black List. Sie betonen, dass es in der EU sehr unterschiedliche Black Lists mit insgesamt mehr als 260 verschiedenen Verarbeitungstätigkeiten gibt, keine Vollharmonisierung und keine einheitliche EU-Liste. Gleichzeitig hat der EDSA EU-weit einheitliche Kriterien herausgegeben, die von Mitgliedstaaten zu berücksichtigen sind. [E2/F12] Die Folien nennen Beispiele: Wenn eines der Kriterien zutrifft, etwa Bewertung oder Einstufung einschließlich Profilerstellung und Prognosen mit potenziell nachteiligen Folgen für Betroffene; Profiling und automatisierte Entscheidungsfindung; Beobachtung, Überwachung oder Kontrolle der Betroffenen, insbesondere im öffentlichen Raum; Zusammenführen oder Abgleichen von Datensätzen aus mehreren Verarbeitungsvorgängen; oder Datenverarbeitung im höchstpersönlichen Bereich, auch mit Einwilligung. Wenn mindestens zwei Kriterien zutreffen, etwa umfangreiche Verarbeitung besonderer Kategorien personenbezogener Daten; Erhebung von Standortdaten im Sinne des TKG; Daten über schutzbedürftige Personen wie Arbeitnehmer, Patienten oder psychisch Kranke; oder Zusammenführung/Abgleich von Datensätzen aus mehreren Verarbeitungen mit unterschiedlichen Zwecken oder verschiedenen Verantwortlichen. [E2/F12]

Bezug zur DSGVO: Art. 35 Abs. 4 DSGVO sieht Listen von Verarbeitungsvorgängen vor, für die eine DSFA durchzuführen ist. Erwägungsgrund 91 DSGVO nennt u. a. umfangreiche Verarbeitung, neue Technologien, sensible Daten, Profiling und weiträumige Überwachung öffentlich zugänglicher Bereiche als typische Hochrisiko-Konstellationen.

10.4 Mindestinhalt der DSFA

Die Folien warnen: Die PIA ist für jede Datenanwendung separat durchzuführen; der Anpassungsbedarf ist in jedem Einzelfall zu prüfen. Mindestinhalt sind eine systematische Beschreibung der Verarbeitung und Zwecke, Bewertung von Notwendigkeit und Verhältnismäßigkeit, Bewertung der Risiken sowie Abwehrmaßnahmen, Garantien, Sicherheitsvorkehrungen und Verfahren. [E2/F13] Außerdem nennen die Folien Möglichkeiten der Standardisierung: Beschreibung der IT-Landschaft, also Hardware, Software, Systeme; IT-Standards wie Virenschutz, Firewall, Backup; Personalstruktur mit Zugriffsrechten, Kontrolle und Berichtslinien; potenzielle Risiken und Eintrittswahrscheinlichkeit; Auflistung von Folgen und Gefahrenklassen; und Ausarbeitung von Risikominimierung bzw. Gegenmaßnahmen. [E2/F13]

Bezug zur DSGVO: Art. 35 Abs. 7 DSGVO nennt als Mindestinhalt einer DSFA: systematische Beschreibung der Verarbeitungsvorgänge und Zwecke, Bewertung der Notwendigkeit und Verhältnismäßigkeit, Bewertung der Risiken für Rechte und Freiheiten und geplante Abhilfemaßnahmen/Garantien/Sicherheitsvorkehrungen.

10.5 Ergebnis, Zweck und Aktualisierung der DSFA

Die Folien erklären die DSFA als Grundlage für Entscheidungen: Ist die Umsetzung des Projekts möglich? Sind einzelne Schritte erforderlich? Sind ausreichende Sicherheitsmaßnahmen festgelegt? Der Zweck ist die Erfüllung von Art. 35 DSGVO, ein wichtiges Dokument für Benachrichtigungen in Notfällen, ein unverzichtbarer Nachweis der Sorgfaltspflicht und damit eine mögliche Entlastung, sowie die Erhöhung der Transparenz im Unternehmen. Aktualisierung ist nötig bei Änderungen im Prozess, nach Eintritt eines bisher unvorhergesehenen Risikos oder bei Änderungen internationaler bzw. technischer Standards. [E2/F14]

Bezug zur DSGVO: Das folgt aus Art. 35 DSGVO, insbesondere der Risiko- und Maßnahmenlogik. Erwägungsgrund 90 DSGVO beschreibt, dass die DSFA Eintrittswahrscheinlichkeit und Schwere hoher Risiken bewertet und Maßnahmen, Garantien und Verfahren zur Risikominderung und zum Nachweis der DSFVOEinhaltung behandelt.

11. Rechenschaftspflicht und Zusammenarbeit mit der Aufsichtsbehörde

11.1 Rechenschaftspflicht statt Genehmigungssystem

Die Folien erklären: Es gibt keine Genehmigungen von Datenverarbeitungen mehr wie vor der DSGVO. Stattdessen bestehen umfassende Dokumentations- und Nachweispflichten, also Rechenschaftspflicht. [E2/F15]

Bezug zur DSGVO: Art. 5 Abs. 2 DSGVO verlangt, dass der Verantwortliche die Grundsätze aus Art. 5 Abs. 1 einhält und deren Einhaltung nachweisen kann. Art. 24 Abs. 1 DSGVO verlangt geeignete technische und organisatorische Maßnahmen, damit Verarbeitung DSGVO-konform erfolgt und der Nachweis erbracht werden kann.

11.2 Datenschutzmanagement-System

Als Lösung nennen die Folien ein Datenschutzmanagement-System. Dieses kann klare interne Zuständigkeiten und, soweit angemessen, interne Richtlinien vorsehen, etwa zum Umgang mit Betroffenenrechten, zur technischen Möglichkeit der Ausübung von Betroffenenrechten und zur Zusammenarbeit mit der Aufsichtsbehörde. [E2/F16]

Bezug zur DSGVO: Art. 24 Abs. 1 DSGVO verlangt Maßnahmen unter Berücksichtigung von Art, Umfang, Umständen und Zwecken der Verarbeitung sowie Risiken. Ein Datenschutzmanagement-System ist ein praktisches Mittel, um diese Pflicht und die Rechenschaft nach Art. 5 Abs. 2 DSGVO zu erfüllen.

11.3 Zusammenarbeit mit der Aufsichtsbehörde

Die Folien nennen eine umfassende Pflicht zur Zusammenarbeit mit der Behörde, jeweils auf Anfrage der Behörde im Zusammenhang mit ihren Aufgaben. In der Regel sind Informationen und Dokumente zu übermitteln, z. B. Bekanntgabe von Auftragsverarbeitern, Übermittlung der Datenschutzerklärung, ergriffene

Sicherheitsmaßnahmen oder Informationen, warum keine PIA durchgeführt wurde.
[E2/F17]

Bezug zur DSGVO: Art. 31 DSGVO verpflichtet Verantwortliche und Auftragsverarbeiter sowie gegebenenfalls deren Vertreter zur Zusammenarbeit mit der Aufsichtsbehörde auf Anfrage. Art. 30 Abs. 4 DSGVO verlangt außerdem, dass Verzeichnisse auf Anfrage zur Verfügung gestellt werden.

12. Datengeheimnis

12.1 Inhalt und praktische Umsetzung

Die Folien erklären das Datengeheimnis als gesetzliche Verschwiegenheitspflicht für Verantwortliche, Auftragsverarbeiter und deren Mitarbeiter, soweit kein rechtlich zulässiger Grund für eine Datenübermittlung besteht. In der Praxis erfolgt dies häufig als Anhang zum Arbeitsvertrag, der unterschrieben wird, oft kombiniert mit anderen Verschwiegenheitspflichten, etwa Schutz von Betriebs- und Geschäftsgeheimnissen nach UWG. [E2/F18]

Pflichten für Verantwortliche und Auftragsverarbeiter sind laut Folien: vertragliche Verpflichtung der Mitarbeiter zur Einhaltung des Datengeheimnisses und Belehrung über zulässige Datenübermittlungen und Folgen einer Verletzung des Datengeheimnisses. [E2/F18-F19]

Bezug zur DSGVO: Die DSGVO verwendet den Begriff „Datengeheimnis“ nicht als zentralen eigenen Artikel wie das österreichische DSG, verlangt aber Vertraulichkeit und Sicherheitsmaßnahmen. Relevante DSGVO-Bezüge sind Art. 5 Abs. 1 lit. f DSGVO zur Integrität und Vertraulichkeit, Art. 28 Abs. 3 lit. b DSGVO zur Vertraulichkeitsverpflichtung von Personen beim Auftragsverarbeiter und Art. 32 DSGVO zu Sicherheitsmaßnahmen.

13. Auftragsverarbeiter und Auftragsverarbeitungsvertrag

13.1 Rollenverteilung

Die Folien definieren Auftragsverarbeiter als jeden, der Daten im Auftrag und auf Weisung des Verantwortlichen verarbeitet und nicht selbst über Zwecke und Art der Verarbeitung entscheidet. Früher wurde diese Rolle als „Dienstleister“ bezeichnet. Wichtig ist die Gesamtsicht: Es muss das Zusammenspiel der Definition von Verantwortlichem/Auftragsverarbeiter in Art. 4 DSGVO mit den Pflichten und Rechten in Art. 28 DSGVO betrachtet werden. Der Verantwortliche entscheidet über Zweck und Umfang; der Auftragsverarbeiter kann in gewissem Maß über das „Wie“, aber nicht über das „Wozu“ der Verarbeitung entscheiden. Die Abgrenzung erfolgt praktisch anhand fachlicher Weisungen. [E2/F20-F21]

Bezug zur DSGVO: Art. 4 Nr. 7 DSGVO definiert Verantwortliche, Art. 4 Nr. 8 DSGVO Auftragsverarbeiter und Art. 28 DSGVO die Verarbeitung im Auftrag.

13.2 Auswahl des Auftragsverarbeiters

Die Folien nennen die Pflicht des Verantwortlichen, bei der Auswahl auf „sufficient guarantees“ nach Art. 28 DSGVO zu achten. Der Auftragsverarbeiter muss hinreichende Garantien dafür bieten, geeignete technische und organisatorische Maßnahmen durchzuführen, damit die Verarbeitung im Einklang mit der DSGVO erfolgt und der Schutz der Betroffenenrechte gewährleistet ist. [E2/F22] Praktisch hängt die Prüfungsintensität von der Kritikalität der Anwendung ab. Häufig erfolgt nur eine rudimentäre Prüfung. Möglich sind vertragliche Absicherungen, Nachweis von Zertifikaten wie ISO/IEC oder Ö-Normen, Prüfung durch unabhängige Dritte, regelmäßige Prüfungen oder Tests, Vorlage von Testergebnissen und Benchmarking. [E2/F22]

Bezug zur DSGVO: Art. 28 Abs. 1 DSGVO erlaubt nur Auftragsverarbeiter, die hinreichende Garantien bieten. Erwägungsgrund 81 DSGVO konkretisiert dies mit Fachwissen, Zuverlässigkeit, Ressourcen und technischen/organisatorischen Maßnahmen.

13.3 Inhalt der Auftragsverarbeitungsvereinbarung

Die Folien verlangen einen Vertrag oder ein vergleichbares Rechtsinstrument. Darin müssen Gegenstand und Dauer der Verarbeitung, Art und Zweck der Verarbeitung, Art personenbezogener Daten, Kategorien betroffener Personen sowie Pflichten und Rechte des Verantwortlichen festgelegt sein. [E2/F23]

Bezug zur DSGVO: Das ist Art. 28 Abs. 3 DSGVO.

13.4 Mindestpflichten im AV-Vertrag

Die Folien nennen als Mindestpflichten: Verarbeitung nur auf dokumentierte Weisung; Verpflichtung der Mitarbeiter zur Vertraulichkeit und Verschwiegenheit; Einhaltung von Datensicherheitsmaßnahmen nach Art. 32 DSGVO; Einhaltung von Zustimmungserfordernis und Widerspruchsrecht bei Subverarbeitern; Unterstützung bei Betroffenenrechten; Unterstützung bei Data-Breach-Meldungen und PIA; Löschung oder Rückgabe nach Beendigung; Zurverfügungstellung aller erforderlichen Informationen; Ermöglichung von Überprüfungen und Inspektionen/Audits. [E2/F24]

Bezug zur DSGVO: Diese Punkte entsprechen Art. 28 Abs. 3 lit. a-h DSGVO.

13.5 Subverarbeiter

Die Folien sagen: Die Einschaltung weiterer Auftragsverarbeiter ist grundsätzlich unbegrenzt möglich, also eine „Endlos-Kette“. Aber Subbeauftragung ist nur mit Genehmigung des Verantwortlichen zulässig, der schriftlich zustimmen muss. Möglich ist eine vorherige gesonderte Genehmigung eines konkreten Subverarbeiters oder eine allgemeine schriftliche Genehmigung. Bei allgemeiner Genehmigung besteht eine Vorab-Informationspflicht des Auftragsverarbeiters, damit der Verantwortliche Einspruch erheben kann. Es braucht einen Subauftragsverarbeitungsvertrag; die Pflichten des Auftragsverarbeiters sind schriftlich auf den Subverarbeiter zu überbinden. Der Auftragsverarbeiter haftet gegenüber dem Verantwortlichen, wenn der

Sub seinen Datenschutzpflichten nicht nachkommt; Subs sind Erfüllungsgehilfen des Auftragsverarbeiters, der wie für eigenes Verhalten haftet. [E2/F25]

Bezug zur DSGVO: Art. 28 Abs. 2 DSGVO regelt Genehmigung und Information bei Subverarbeitern. Art. 28 Abs. 4 DSGVO verlangt die Überbindung derselben Datenschutzpflichten und regelt die Haftung des ursprünglichen Auftragsverarbeiters.

13.6 Musterformulierung Subverarbeitung

Die Folien enthalten eine Musterformulierung: Der Verantwortliche erteilt dem Auftragsverarbeiter eine allgemeine schriftliche Genehmigung nach Art. 28 Abs. 2 DSGVO, andere Unternehmen als Subverarbeiter heranzuziehen. Der Auftragsverarbeiter muss den Verantwortlichen so rechtzeitig informieren, dass dieser die Heranziehung untersagen kann. Außerdem muss ein Vertrag nach Art. 28 Abs. 4 DSGVO geschlossen werden, in dem der Subverarbeiter dieselben Pflichten übernimmt. Zusätzlich soll der Auftragsverarbeiter sicherstellen, dass der Verantwortliche dem Subverarbeiter direkt Weisungen erteilen kann, sofern dies datenschutzrechtlich erforderlich ist. [E2/F26]

13.7 Praktische Vertragsgestaltung

Die Folien nennen EDPB-Ausgestaltungsempfehlungen aus Sicht des Verantwortlichen: Weisungsgebundenheit möglichst im Hauptvertrag vereinbaren; konkreten Prozess der Weisungserteilung festlegen; Datengeheimnis regeln; Datenminimierungs- und Zweckbindungsgrundsatz spezifizieren, z. B. durch Beschränkung von Zugriffsrechten und Nachweispflichten des Auftragsverarbeiters; bei Subverarbeitern Vorabübermittlung der Sub-AVV an den Verantwortlichen; Audit regeln; Kooperationspflicht des Auftragsverarbeiters vorsehen; und Kostenübernahme durch den Auftragsverarbeiter bei nachweisbarem Verstoß. [E2/F27]

Bezug zur DSGVO: Diese Punkte operationalisieren Art. 28 Abs. 3 und 4 DSGVO, außerdem die Grundsätze aus Art. 5 DSGVO und die Sicherheitspflichten aus Art. 32 DSGVO.

14. Gemeinsame Verantwortliche

14.1 Vereinbarung nach Art. 26 DSGVO

Die Folien erklären, dass bei gemeinsamen Verantwortlichen eine zwingende interne Vereinbarung erforderlich ist. Darin muss geregelt werden, wer welche Verpflichtungen gemäß DSGVO erfüllt, insbesondere die Wahrnehmung von Betroffenenrechten. Die Regelung muss wahrheitsgemäß und klar sein. Es gibt kein Formerfordernis, aber Verschriftlichung ist empfehlenswert. Die wesentlichen Inhalte sind gegenüber Betroffenen offenzulegen. Es soll eine Anlaufstelle für Betroffene bzw. zentrale Kontaktstelle genannt werden. Trotzdem können Betroffene sich an jeden gemeinsam Verantwortlichen wenden. Gegenüber Betroffenen besteht solidarische Haftung. [E2/F28-F30]

Bezug zur DSGVO: Art. 26 Abs. 1 DSGVO verlangt eine transparente Festlegung der Pflichten. Art. 26 Abs. 2 DSGVO verlangt, dass das Wesentliche der Vereinbarung betroffenen Personen zur Verfügung gestellt wird. Art. 26 Abs. 3 DSGVO stellt klar, dass Betroffene ihre Rechte gegenüber jedem Verantwortlichen geltend machen können.

15. Datenverarbeitung zu spezifischen Zwecken: Wissenschaft, Forschung,

Bildaufnahme

15.1 Wissenschaft und Forschung – Spannungsverhältnis

Die Folien stellen Wissenschaft und Forschung als Spannungsverhältnis zwischen öffentlichem Interesse und Interesse des Einzelnen dar. Genannt wird Art. 89 DSGVO: geeignete Garantien für die Verarbeitung, insbesondere Pseudonymisierung; mögliche Einschränkung bestimmter Betroffenenrechte; Öffnungsklausel für Mitgliedstaaten. Österreich hat davon laut Folien umfassend Gebrauch gemacht. [E2/F31-F32]

Bezug zur DSGVO: Art. 89 Abs. 1 DSGVO verlangt geeignete Garantien für Rechte und Freiheiten bei Verarbeitung zu Archiv-, Forschungs- oder Statistikzwecken, insbesondere technische und organisatorische Maßnahmen wie Datenminimierung und gegebenenfalls Pseudonymisierung. Art. 89 Abs. 2 DSGVO erlaubt unter Bedingungen Einschränkungen bestimmter Betroffenenrechte.

15.2 Forschung nach österreichischem Recht

Die Folien unterscheiden Ergebnisse ohne und mit Personenbezug. Ergebnis ohne Personenbezug: Verarbeitung nur, wenn Daten öffentlich zugänglich sind, für andere Untersuchungen oder Zwecke ermittelt wurden oder pseudonymisiert sind. Ergebnis mit Personenbezug: Verarbeitung nur bei speziellen gesetzlichen Regelungen, Einwilligung der Betroffenen oder Genehmigung der Datenschutzbehörde. Die Folien sprechen von starken Erleichterungen für Forschungszwecke, aber auch umfassenden und detaillierten Auflagen für Verantwortliche. Genannt werden das Forschungsorganisationsgesetz (FOG) als *lex specialis* und § 7 DSG. [E2/F33]

Bezug zur DSGVO: Die nationale Ausgestaltung beruht auf den Öffnungsmöglichkeiten aus Art. 89 DSGVO.

15.3 Bildaufnahme und Videoaufzeichnung

Die Folien behandeln Sonderbestimmungen für „Bildaufnahme“ statt bloß Videoüberwachung. §§ 12 und 13 DSG wurden vom BVwG für nicht anwendbar erklärt, bleiben aber laut Folien praktisch relevant. Genannt werden die Entscheidungen BVwG 20.11.2019, W256 2214855-1, und 25.11.2019, W211 2210458-1. Der Anwendungsbereich wird als erweitert beschrieben: jede Feststellung von Ereignissen, auch begleitende Tonaufnahme. [E2/F34] Praxisnahe Zulässigkeitsbestimmungen laut Folien sind: vorbeugender Schutz privater Liegenschaften, einschließlich unvermeidbarer Einbeziehung öffentlicher Verkehrsflächen; vorbeugender Schutz öffentlich

zugänglicher Orte; privates Dokumentationsinteresse, z. B. Actioncam. Bei Dashcams wird gewarnt: keine anlasslose Dokumentation zur Beweismittelsammlung. Genannt wird BVwG 25.10.2022, W256 2222862-1, sowie die FAQ der Datenschutzbehörde. Weiterhin unzulässig sind Aufnahmen im höchstpersönlichen Lebensbereich und die Kontrolle von Arbeitnehmern. [E2/F34]

Bezug zur DSGVO: Je nach Fall kommen Art. 5 DSGVO (Grundsätze), Art. 6 DSGVO (Rechtsgrundlage), ggf. Art. 9 DSGVO bei sensiblen Daten und Art. 35 DSGVO bei hohem Risiko in Betracht. Beschäftigtenkontrolle ist wegen besonderer Schutzbedürftigkeit auch im Licht von Erwägungsgrund 75 DSGVO risikorelevant.

16. Technische und organisatorische Maßnahmen (TOMs)

16.1 TOMs als Werkzeug der DSGVO-Compliance

Die Folien ordnen TOMs drei Artikeln zu: Art. 25 DSGVO zur Einhaltung von Datenschutzgrundsätzen und Schutz der Betroffenenrechte, Art. 24 DSGVO zur Sicherstellung und zum Nachweis der Compliance und Art. 32 DSGVO zum angemessenen Schutzniveau für Daten. Verantwortliche sind direkt verpflichtet;

Auftragsverarbeiter sind mittelbar bzw. bei Art. 32 unmittelbar relevant. TOMs sind das Werkzeug, um diese Ziele zu erreichen. [E3/F2-F3]

Bezug zur DSGVO: Art. 24 Abs. 1 DSGVO verlangt geeignete TOMs zur Sicherstellung und zum Nachweis der DSGVO-konformen Verarbeitung. Art. 25 DSGVO verlangt Datenschutz durch Technikgestaltung und datenschutzfreundliche Voreinstellungen. Art. 32 DSGVO verlangt Sicherheit der Verarbeitung.

16.2 Regelmäßige Evaluierung und PDCA-Zyklus

Die Folien betonen, dass TOMs regelmäßig zu evaluieren sind, also nicht einmalig genügen. Genannt wird der PDCA-Zyklus. Zu berücksichtigen sind Stand der Technik, Implementierungskosten, Art, Umfang, Umstände und Zweck der Verarbeitung sowie Eintrittswahrscheinlichkeit und Schwere der Risiken. [E3/F4]

Bezug zur DSGVO: Diese Faktoren stehen ausdrücklich in Art. 24 Abs. 1 DSGVO, Art. 25 Abs. 1 DSGVO und Art. 32 Abs. 1 DSGVO. Der Gedanke regelmäßiger Überprüfung wird in Art. 32 Abs. 1 lit. d DSGVO konkretisiert.

16.3 Datenschutz durch Technik und Voreinstellungen

Die Folien erklären Privacy by Design and by Default nach Art. 25 DSGVO. Durch Voreinstellungen sollen nur die für den Zweck erforderlichen Daten verarbeitet werden. Datenschutz ist frühzeitig sicherzustellen, z. B. bei Produktentwicklungen und Produkteinführungen sowie bei der Leistungsdefinition. Zu berücksichtigen sind Umfang der erhobenen Daten, Umfang der Verarbeitung, Speicherfrist und Zugänglichkeit. Die Folien nennen außerdem transparente Funktionen, Überwachung durch Betroffene ermöglichen sowie Sicherheitsfunktionen schaffen und verbessern. [E3/F5]

Bezug zur DSGVO: Art. 25 Abs. 1 DSGVO verlangt Datenschutz durch Technikgestaltung bereits zum Zeitpunkt der Festlegung der Mittel und während der Verarbeitung. Art. 25 Abs. 2 DSGVO verlangt datenschutzfreundliche Voreinstellungen: nur erforderliche Daten, nur erforderlicher Umfang, nur erforderliche Speicherfrist und nur erforderliche Zugänglichkeit.

16.4 Datenschutz nicht nur „on top“

Die Folien betonen, dass geeignete TOMs gesetzt werden müssen, um Datenschutzgrundsätze, sonstige DSGVO-Pflichten und Betroffenenrechte wirksam umzusetzen. Verantwortlich sind die Verantwortlichen, nicht die Entwickler. Trotzdem soll Datenschutz nicht nachträglich „on top“ ergänzt werden, sondern bereits im Entwicklungsstadium berücksichtigt werden. [E3/F6]

Bezug zur DSGVO: Das ist der praktische Kern von Art. 25 DSGVO. Erwägungsgrund 78 DSGVO beschreibt Maßnahmen wie Datenminimierung, rasche Pseudonymisierung, Transparenz, Überwachbarkeit durch Betroffene und Sicherheitsfunktionen.

16.5 Sicherheitsziele nach Art. 32 DSGVO

Die Folien nennen konkrete Ziele der Datensicherheit nach Art. 32 Abs. 1 DSGVO: Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit der Systeme und Dienste; Verfügbarkeit der Daten; rasche Wiederherstellung des Zugangs bei physischem oder technischem Zwischenfall. Beispielhafte Maßnahmen sind Pseudonymisierung, Verschlüsselung und Verfahren zur regelmäßigen Überprüfung, Bewertung und Evaluierung der Wirksamkeit der TOMs. [E3/F7]

Bezug zur DSGVO: Das entspricht Art. 32 Abs. 1 lit. a-d DSGVO.

16.6 Technische Maßnahmen

Die Folien nennen als technische Maßnahmen Best Practices, insbesondere ISO-Standards wie die ISO/IEC27000-Familie, ÖNORMEN und das österreichische Informationssicherheitshandbuch. Allgemein zu setzende Sicherheitsmaßnahmen sind Zugriffskontrolle, Berechtigungssysteme, Passwortsicherheit, Disaster Recovery und Business Continuity, z. B. Backups. [E3/F8]

Bezug zur DSGVO: Diese Maßnahmen dienen dem angemessenen Schutzniveau nach Art. 32 DSGVO und dem Nachweis nach Art. 24 DSGVO.

16.7 Organisatorische Maßnahmen

Als organisatorische Maßnahmen nennen die Folien personelle Sicherheit, Verschwiegenheit und Schulungen, sichere physische Umgebung wie Brandschutz und Stromversorgung, Mitarbeiter-Awareness, Anpassung bzw. Erstellung von IT-Richtlinien, Regelung erlaubter Geräte, Sicherstellung von Datengeheimnis und Betriebs-/Geschäftsgeheimnissen, Leitfäden für Telefonkonferenzen und Videokonferenzen im Homeoffice sowie Regeln zum Umgang mit externen Speichermedien. [E3/F9]

Bezug zur DSGVO: Auch dies fällt unter Art. 32 DSGVO und die allgemeine Pflicht aus Art. 24 DSGVO.

17. Datenschutz im Homeoffice

17.1 Awareness, Richtlinien und Geräte

Die Folien verwenden Homeoffice als Praxisbeispiel. Erforderlich sind Mitarbeiter-Awareness, Anpassung oder Erstellung von IT-Richtlinien, Regelung der erlaubten Geräte, Erinnerungen im Anlassfall und Vorbereitung der IT-Systeme. Dazu gehören Kapazitäten, Verfügbarkeit, Updates, Ausstattung mit Firmengeräten wie Laptops und Smartphones, ausreichende Lizenzen und Belastbarkeiten sowie Regelung zum Austausch defekter Geräte. Die Risikoerhöhung durch Fernzugriff ist zu berücksichtigen, etwa durch verschlüsselte VPN-Verbindung, VDI und Zwei-Faktor-Authentifizierung. Bei privaten Geräten ist besondere Vorsicht nötig, z. B. MDM oder Container-Lösungen. [E3/F10]

Bezug zur DSGVO: Diese Maßnahmen sind TOMs nach Art. 32 DSGVO, insbesondere zur Vertraulichkeit, Integrität, Verfügbarkeit und Belastbarkeit.

17.2 Backups, Berichtswege und Kommunikationsmittel

Die Folien nennen eine Neubewertung und gegebenenfalls Anpassung der TOMs, regelmäßige Backups, Sicherstellung der Berichtswege, insbesondere wegen der 72-Stunden-Frist bei Data Breaches, besondere Vorsicht bei Spam, Malware und Phishing, Überprüfung der verwendeten Kommunikationsmittel für berufliche Informationen, kein Software-Download bzw. keine Installation am Firmengerät ohne Freigabe, Vorsicht bei kostenlosen internetbasierten Anbietern, klare Weisungen und Vorgaben sowie besondere Vorsicht bei Videokonferenzen. Bei Videokonferenzen werden Zurückhaltung bei sensiblen Inhalten, Umgang mit bzw. Sperrung von Aufzeichnungsfunktionen und Regelungen für Chat-Inhalte genannt. [E3/F11]

Bezug zur DSGVO: Neben Art. 32 DSGVO ist hier auch Art. 33 DSGVO relevant, weil bei Datenschutzverletzungen die Meldung an die Aufsichtsbehörde grundsätzlich binnen 72 Stunden erfolgen

muss.

17.3 Datengeheimnis und Papierdokumente im Homeoffice

Die Folien nennen die Sicherstellung des Datengeheimnisses und des Schutzes von Geschäftsgeheimnissen, Richtlinien für Telefon- und Videokonferenzen, Geheimhaltung von Passwörtern, Vermeidung von Schattendatenbanken, Regeln zur Nutzung externer Speichermedien und ausdrücklich auch Regeln für Papierdokumente. Auch im Homeoffice gilt ein sauberer Schreibtisch. Für Papierunterlagen sind Lagerung und Konsolidierung bei Rückkehr ins Büro sowie Vernichtung während bzw. nach dem Homeoffice zu regeln. [E3/F12]

Bezug zur DSGVO: Das dient insbesondere Art. 5 Abs. 1 lit. f DSGVO und Art. 32 DSGVO.

17.4 Beispiele für Strafen wegen unzureichender TOMs

Die Folien nennen DSGVO-Strafen im ersten Quartal 2025 wegen unzureichender TOMs: Rumänien, 15.000 EUR gegen UniCredit RON wegen unzureichender Sicherheitsmaßnahmen, die Zugriff auf Kreditantragsinformationen ermöglichten; Spanien, 5 Mio. EUR gegen Generali España wegen fehlender AppSicherheit, wobei ein Testing Plan vor Go-live verlangt wurde; Finnland, 950.000 EUR infolge eines Data Breach durch technische Fehler, mit 1,5 Mio. Betroffenen. [E3/F13]

Bezug zur DSGVO: Bußgelder können insbesondere auf Verletzungen von Art. 32 DSGVO und über Art. 83 DSGVO gestützt werden.

18. Data Breaches / Datenschutzverletzungen

18.1 Beispiele und Definition

Die Folien fragen zunächst, was ein Data Breach ist, und nennen Beispiele: Diebstahl mobiler Geräte wie Laptop oder Firmenhandy, Verlust von Hardcopy-Unterlagen und Dokumenten, liegen gelassener USB-Stick, Hackerangriff, Ransomware-Attacke, von einem ehemaligen Mitarbeiter „abgezogene“ Datensätze, E-Mail an falsche Empfänger. Ein Data Breach kann beim Verantwortlichen oder beim Auftragsverarbeiter eintreten. [E3/F14-F16] Die Definition in den Folien lautet sinngemäß: jede Verletzung der Sicherheit, die zu unbeabsichtigter oder unbefugter Vernichtung, Verlust, Veränderung, Offenlegung oder Zugang führt. [E3/F16]

Bezug zur DSGVO: Das entspricht Art. 4 Nr. 12 DSGVO, der die Verletzung des Schutzes personenbezogener Daten definiert als Verletzung der Sicherheit, die zur Vernichtung, zum Verlust, zur Veränderung oder zur unbefugten Offenlegung bzw. zum unbefugten Zugang zu personenbezogenen Daten führt.

18.2 Risikobeurteilung

Die Folien betonen: Maßgeblich sind die Risiken für Betroffene. Die Risikobeurteilung erfolgt als Gesamtabwägung. Kriterien sind Art der Datenschutzverletzung, z. B. unbefugte Offenlegung oder Verlust; Art, Sensibilität und Umfang der betroffenen Daten; Möglichkeit, betroffene Personen zu identifizieren; Schwere und Wahrscheinlichkeit drohender Konsequenzen; besonders schutzwürdige Betroffene; und Anzahl betroffener Personen. Ein hohes Risiko liegt jedenfalls nahe bei drohenden Schäden oder wenn Betroffene selbst Maßnahmen setzen müssen. [E3/F17]

Bezug zur DSGVO: Art. 33 DSGVO knüpft die Meldepflicht an ein Risiko für Rechte und Freiheiten natürlicher Personen. Art. 34 DSGVO verlangt Benachrichtigung der Betroffenen bei hohem Risiko. Erwägungsgrund 75 DSGVO nennt mögliche Schäden wie Diskriminierung, Identitätsdiebstahl, finanziellen Verlust, Rufschädigung oder Verlust der Vertraulichkeit.

18.3 72-Stunden-Frist und interne Dokumentation Die Folien verlangen eine Evaluierung des Risikos innerhalb von maximal 72 Stunden ab Kenntnis vom Data

Breach. Außerdem sind alle Datenvorfälle umfassend intern zu dokumentieren. Wenn kein Risiko besteht, genügt interne Dokumentation. Wenn ein Risiko besteht, ist zusätzlich Meldung an die Datenschutzbehörde erforderlich. Bei hohem Risiko ist zusätzlich die Benachrichtigung der Betroffenen erforderlich. [E3/F18]

Bezug zur DSGVO: Art. 33 Abs. 1 DSGVO verlangt Meldung an die Aufsichtsbehörde unverzüglich und möglichst binnen 72 Stunden, wenn die Verletzung voraussichtlich ein Risiko für Rechte und Freiheiten natürlicher Personen darstellt. Art. 33 Abs. 5 DSGVO verlangt Dokumentation aller Verletzungen, ihrer Umstände, Auswirkungen und Abhilfemaßnahmen. Art. 34 Abs. 1 DSGVO verlangt Benachrichtigung der Betroffenen bei hohem Risiko.

18.4 Meldung und Benachrichtigung

Die Folien nennen die unverzügliche, möglichst binnen 72 Stunden erfolgende Meldung an die Datenschutzbehörde. Die Meldung muss Beschreibung der Art der Verletzung, Kategorien und Zahl der Betroffenen und Daten, Namen und Kontaktdaten des Datenschutzbeauftragten, wahrscheinliche Folgen sowie ergriffene oder vorgeschlagene Gegenmaßnahmen enthalten. Bei hohem Risiko kommt zusätzlich eine unverzügliche Benachrichtigung der Betroffenen hinzu. Wenn individuelle Benachrichtigung unverhältnismäßig wäre, kann öffentliche Bekanntmachung erfolgen. Praxistipp der Folien: Im Zweifel eher melden. Die Benachrichtigung der Betroffenen kann von der Datenschutzbehörde angeordnet werden. [E3/F19]

Bezug zur DSGVO: Inhalt der Meldung: Art. 33 Abs. 3 DSGVO. Benachrichtigung der Betroffenen: Art. 34 DSGVO. Öffentliche Bekanntmachung bei unverhältnismäßigem Aufwand: Art. 34 Abs. 3 lit. c DSGVO. Anordnung durch Behörde: Art. 34 Abs. 4 DSGVO.

18.5 EDSA-Beispiele

Die Folien nennen EDSA-Guideline-Beispiele. Erstes Beispiel: Daten aus einem Online-Bewerbungsformular werden durch bösartigen Code via SQL Injection abgeschöpft und erst einen Monat später entdeckt. Ergebnis laut Folien: Meldepflicht an DSB/Aufsichtsbehörde und Benachrichtigungspflicht gegenüber Betroffenen; Risiken sind Spam-Mails, Identitätsdiebstahl usw., unabhängig davon, ob sensible Daten betroffen sind. Maßnahmen: Entfernung von Malware/bösartigem Code, verbesserte Sicherheitsmaßnahmen, Wiederherstellung von Daten. [E3/F20] Zweites Beispiel: Ein Mitarbeiter kopiert Kundendaten und nutzt Kontakte nach Ausscheiden für eigene Zwecke. Ergebnis: Meldung an Aufsichtsbehörde ja, Benachrichtigung Betroffener nein. Risiken sind Spam und Cold Calling. Maßnahmen: rechtliche Schritte gegen Mitarbeiter, Zugriffe überwachen, Dienstleistungsvertrag sollte eine solche Verarbeitung verbieten. [E3/F20] Drittes Beispiel: falscher E-Mail-Empfänger, Empfänger unterliegt Berufsgeheimnis, Daten von 24 Personen, keine sensiblen Daten, Empfänger meldet und löscht die Nachricht. Ergebnis: keine Meldung und keine

Benachrichtigung, weil kein Risiko, wenn Empfänger sofort kontaktiert wurde und Löschung bestätigt hat. Maßnahme: Awareness-Training. [E3/F21] Viertes Beispiel: unbeabsichtigte Weitergabe von Bewerberdaten per E-Mail, sensible Daten wie Sozialversicherungsnummer, mehr als 6.000 Betroffene. Ergebnis: Meldepflicht und Benachrichtigungspflicht, weil weitere Nutzung nicht ausgeschlossen werden kann.

Maßnahmen: nur eingeschränkte Möglichkeiten, Anfrage zur Löschung, Awareness-Training. [E3/F21]

Bezug zur DSGVO: Diese Beispiele konkretisieren die Risikoabstufung aus Art. 33 und 34 DSGVO.

19. Ransomware-Anlassfall und Incident Handling

19.1 Erster Status und Krisenmodus

Die Folien nutzen Ransomware als Beispiel für den Anlassfall. Richtiges Verhalten beginnt mit Statuserhebung: Welche Systeme sind betroffen? Gibt es globalen Ausfall? Welche Auswirkungen hat das auf das Business? Ist externe Transparenz betroffen? Ist E-Mailverkehr betroffen? Ist VoIP-Telefonie betroffen? Außerdem sind definierte Verfahrensabläufe wie Krisenstab und Ablaufdokumentation abzurufen. Im Erstmoment ist zu klären, ob eine Erpressernachricht vorhanden ist, ob ein Ultimatum definiert ist, welche Reaktionszeit bzw. Restzeit bleibt, ob Schnittstellensysteme wie Bestellsysteme oder Serviceportale betroffen sind und ob die Website betroffen ist. [E3/F22-F23]

Bezug zur DSGVO: Diese Schritte dienen der Risikobewertung und Meldungsfähigkeit nach Art. 33 DSGVO sowie der Wiederherstellung und Belastbarkeit nach Art. 32 Abs. 1 lit. b-c DSGVO.

19.2 Meldungen, Krisenstab, Recovery und externe Kommunikation

Die Folien nennen als weitere Schritte: Meldungen und externe Kommunikation vorbereiten; Meldung innerhalb der Frist, aber bereits mit genügend Inhalt an die Datenschutzbehörde; Krisenstab und RecoveryTeam aufstellen; Entscheidungen treffen; prüfen, ob externe Unterstützung gebraucht wird, etwa Krisenmanagement, IT oder Recht; Krisenstab inklusive kommerzieller Entscheidungsträger definieren; prüfen, ob in den Fristen erste Schritte wie Datenverlustanalyse oder Loganalyse eingeleitet werden können; klären, wer eventuelle Verhandlungen mit dem Erpresser führt und wie; prüfen, ob Kryptowährungskonto bzw. Erfahrung im Umgang damit vorhanden ist; Anzeigen bei Behörden wie LKA, BKA oder FMA; externe Kommunikation an Partner, Lieferanten, Kunden; Versicherungsmeldung; Projektteam inklusive externer Ressourcen oder Partner definieren; Recoveryplan inklusive Priorisierung und Timeline prüfen und finalisieren. [E3/F24]

Bezug zur DSGVO: Für Datenschutz gilt insbesondere Art. 33 DSGVO. Je nach Risiko kann Art. 34 DSGVO für Betroffenenbenachrichtigungen hinzukommen. Technische Wiederherstellung gehört zu Art. 32 DSGVO.

19.3 Betriebsübergabe, Lessons Learned und Nacharbeiten

Nach Wiederherstellung nennen die Folien Abnahme bzw. Betriebsübergabe: IT übergibt jedes finale System wie sonst an den Business Owner. Danach folgen Lessons Learned und Dokumentation: Dokumentationen festhalten, Ablaufpläne nacharbeiten und erweitern, Vier-Augen-Kontrolle bei kritischen Systemen, Erweiterung der

Lieferantenkreise, Standby-Verträge für Businesspartner und weitere Verbesserungen. [E3/F25]

Bezug zur DSGVO: Diese Nacharbeit unterstützt Art. 24 DSGVO und Art. 32 Abs. 1 lit. d DSGVO, weil Wirksamkeit von TOMs regelmäßig überprüft, bewertet und evaluiert werden muss.

19.4 Lessons Learned aus der Praxis

Die Folien nennen vorbereitende Maßnahmen: Plan für Zwischenfälle, klare Berichtswege, Schulungen und Sensibilisierungsmaßnahmen. Als Ad-hoc-Maßnahmen nennen sie zügige Bearbeitung innerhalb der 72-Stunden-Frist, schnelle Umsetzung von Maßnahmen zur Risikominderung und sofortige Dokumentation unabhängig von der Meldepflicht. [E3/F26]

Bezug zur DSGVO: Vorbereitende und Ad-hoc-Maßnahmen dienen Art. 32 DSGVO, Art. 33 DSGVO und der Rechenschaftspflicht nach Art. 5 Abs. 2 DSGVO.

20. Datenschutzbeauftragte / DSBA

20.1 Allgemeines Rollenverständnis

Die Folien beschreiben den Datenschutzbeauftragten als sachkundige Ansprechperson, intern oder extern. Er ist aber nicht die Aufsichtsbehörde. Die Rolle wird als neues Berufsbild durch die DSGVO dargestellt. Genannt wird der Verein österreichischer betrieblicher und behördlicher Datenschutzbeauftragter. Grundidee ist die Verbesserung der Datenschutzcompliance durch Selbstkontrolle und Eigenverantwortung. [E3/F27-F28]

Bezug zur DSGVO: Datenschutzbeauftragte sind in Art. 37-39 DSGVO geregelt.

20.2 Keine allgemeine Bestellungspflicht

Die Folien betonen: Es gibt keine allgemeine Bestellungspflicht. Der Umsetzungsspielraum der DSGVO wurde im österreichischen DSG nicht genutzt. Es gibt keine Bestellungspflicht bei Erreichen bestimmter Kennzahlen und keine Ausnahmen abhängig von Unternehmensgröße oder Mitarbeiteranzahl, anders als in Deutschland. Die Bestellungspflicht ist anhand der vagen Kriterien der DSGVO zu prüfen. [E3/F29]

Bezug zur DSGVO: Art. 37 Abs. 1 DSGVO nennt die verpflichtenden Bestellfälle; eine allgemeine Pflicht für alle Unternehmen enthält die DSGVO nicht.

20.3 Verpflichtende Bestellung nach Art. 37 DSGVO

Nach den Folien ist ein Datenschutzbeauftragter verpflichtend zu bestellen für Behörden oder öffentliche Stellen sowie für Unternehmen, deren Kerntätigkeit in umfangreicher, regelmäßiger und systematischer Überwachung besteht oder in umfangreicher Verarbeitung sensibler bzw. strafrechtlich relevanter Daten. [E3/F29]

Bezug zur DSGVO: Das entspricht Art. 37 Abs. 1 lit. a-c DSGVO: Behörden/öffentliche Stellen; Kerntätigkeit mit umfangreicher regelmäßiger und systematischer Überwachung; Kerntätigkeit mit umfangreicher Verarbeitung besonderer Kategorien nach Art. 9 DSGVO oder Strafdaten nach Art. 10 DSGVO.

20.4 Auslegung von Kerntätigkeit, umfangreich, regelmäßig und systematisch

Die Folien erklären Kerntätigkeit als Haupttätigkeit des Unternehmens, nicht bloße Nebentätigkeit. Genannt wird Erwägungsgrund 97 DSGVO. „Umfangreich“ bedeutet große Datenmengen, große Anzahl von Betroffenen, potenziell hohes Risiko; genannt wird Erwägungsgrund 91 DSGVO. Weitere Faktoren nach der

Art-29-Datenschutzgruppe sind Dauer und geografischer Umfang der Verarbeitung. „Regelmäßig“ bedeutet ständig oder in bestimmten Abständen bzw. zu bestimmten Zeiten. „Systematisch“ bedeutet organisiert, methodisch oder strategisch. Als EDSA-Beispiel für Bestellungspflicht nennen die Folien GPS-Überwachung bzw. Location Tracking, etwa durch mobile Apps. [E3/F30]

Bezug zur DSGVO: Erwägungsgrund 97 DSGVO erklärt, dass Kerntätigkeit Haupttätigkeit meint, nicht Verarbeitung als Nebentätigkeit. Erwägungsgrund 91 DSGVO beschreibt umfangreiche Verarbeitung großer Datenmengen bzw. vieler Betroffener und hohes Risiko.

20.5 Stellung des Datenschutzbeauftragten

Die Folien nennen die Stellung nach Art. 38 DSGVO: unabhängig und weisungsfrei bei Wahrnehmung seiner Aufgaben; darf wegen Aufgabenerfüllung nicht entlassen oder benachteiligt werden; Verantwortlicher bzw. Auftragsverarbeiter bleiben für die Einhaltung verantwortlich; frühzeitige Einbindung in Datenschutzfragen; notwendige Ressourcen einschließlich Schulung und Ausbildung; Zugang zu Daten und Verarbeitungstätigkeiten; direkte Berichtslinie zur höchsten Managementebene; Betroffene können den DSB konsultieren. [E3/F31]

Bezug zur DSGVO: Art. 38 Abs. 1-6 DSGVO enthält diese Anforderungen, insbesondere Einbindung, Ressourcen, Weisungsfreiheit, Benachteiligungsverbot, direkte Berichtslinie und Kontaktmöglichkeit für Betroffene.

20.6 Auswahl des Datenschutzbeauftragten

Die Folien verlangen rechtliche, technische und organisatorische Kenntnisse. Der DSBA kann intern oder extern sein. Interessenkonflikte sind zu vermeiden; daher soll keine Person mit Entscheidungsbefugnis in Datenschutzangelegenheiten bestellt werden, weil sie sich sonst selbst beraten und kontrollieren würde. Außerdem soll der DSBA nicht gleichzeitig Verantwortlicher im Sinne des § 9 VStG sein, wegen der Anordnungsbefugnis. Auswahlkriterien sind berufliche Qualifikation, Fachkenntnisse auf dem Gebiet des Datenschutzrechts und der Datenschutzpraxis sowie die Fähigkeit, DSGVO-Aufgaben zu erfüllen. [E3/F32]

Bezug zur DSGVO: Art. 37 Abs. 5 DSGVO verlangt Benennung nach beruflicher Qualifikation, Fachwissen im Datenschutzrecht und Datenschutzpraxis sowie Fähigkeit zur Erfüllung der

Aufgaben nach Art. 39 DSGVO. Art. 38 Abs. 6 DSGVO erlaubt andere Aufgaben, solange kein Interessenkonflikt entsteht.

20.7 Interne und externe Datenschutzbeauftragte, Datenschutzteam

Die Folien nennen interne Datenschutzbeauftragte typischerweise in Compliance-, Rechts- oder IT-Abteilungen, aber in der Regel nicht als Leiter der Abteilung. Externe Datenschutzbeauftragte sind oft bei KMU. Ein Datenschutzteam ist möglich: rein intern mit einem echten unabhängigen Datenschutzbeauftragten an der Spitze oder gemischt mit externem Dienstleister, z. B. Rechtsanwaltskanzlei, und direktem internem Kontakt. Persönliches Profil und soziale Kompetenz sind ebenso wichtig wie Erfahrung. Der DSBA sollte im Unternehmen anerkannt bzw. geschätzt sowie lösungsorientiert und pragmatisch sein. [E3/F33]

Bezug zur DSGVO: Art. 37 Abs. 6 DSGVO erlaubt interne oder externe Datenschutzbeauftragte.

20.8 Ablauf in der Praxis und Datenschutzkoordinator

Die Folien empfehlen, intern immer die Prüfung der Bestellungspflicht zu dokumentieren; diese muss der Behörde auf Verlangen vorgelegt werden. Wenn kein verpflichtender DSBA erforderlich ist, kann freiwillig ein

Datenschutzbeauftragter bestellt werden, dann sind aber die DSGVO-Bestimmungen voll anwendbar. Praxistipp: Stattdessen Datenschutzkoordinatoren bestellen. Diese sind keine Datenschutzbeauftragten im Sinne der DSGVO, können über Angelegenheiten entscheiden, sind nicht an die DSBA-Regeln der DSGVO gebunden, dienen als interne Anlaufstelle und können bei Bedarf Kontakt zur Behörde haben. [E3/F34]

Bezug zur DSGVO: Die freiwillige Benennung ist nicht verboten; wenn aber ein DSB im Sinne der DSGVO benannt wird, gelten Art. 37-39 DSGVO vollständig.

20.9 Geheimhaltungsverpflichtung des DSBA

Die Folien nennen eine Pflicht zur Geheimhaltung und Vertraulichkeit. Ausnahme ist die Entbindung durch die betroffene Person. Die Geheimhaltung gilt nicht gegenüber der Datenschutzbehörde. Sie gilt intern und extern und auch nach Ende der Tätigkeit; zusätzlich können z. B. Bankgeheimnis oder ärztliche Verschwiegenheitspflicht relevant sein. [E3/F35]

Bezug zur DSGVO: Art. 38 Abs. 5 DSGVO verpflichtet Datenschutzbeauftragte zur Geheimhaltung oder Vertraulichkeit nach Unionsrecht oder mitgliedstaatlichem Recht.

20.10 Aufgaben nach Art. 39 DSGVO

Die Folien nennen als Aufgaben nach Art. 39 DSGVO: Beratung des Verantwortlichen bzw. Auftragsverarbeiters und seiner Beschäftigten in Datenschutzfragen, Überwachung der Einhaltung datenschutzrechtlicher Pflichten, Beratung bei PIA und Überwachung ihrer Durchführung, Zusammenarbeit mit und Anlaufstelle für die Datenschutzbehörde. Außerdem kann der DSBA die Aufsichtsbehörde kostenlos kontaktieren, nach Art. 57 Abs. 3 DSGVO. [E3/F36]

Bezug zur DSGVO: Art. 39 Abs. 1 DSGVO enthält die Aufgaben. Art. 57 Abs. 3 DSGVO sieht vor, dass Leistungen der Aufsichtsbehörde für betroffene Personen und Datenschutzbeauftragte unentgeltlich sind.

20.11 Beratung durch den DSBA

Die Folien erklären Art. 39 Abs. 1 lit. a DSGVO: Der DSBA unterrichtet über allgemeine Pflichten und berät zu konkreten Verarbeitungen. Dies umfasst Verantwortliche bzw. Auftragsverarbeiter und Mitarbeiter. Der DSBA prüft datenschutzrechtliche Verträge, erstellt sie aber nicht. Schulungen der Mitarbeiter sind grundsätzlich nicht erfasst. [E3/F37]

20.12 Kontrolle durch den DSBA

Die Folien erklären Art. 39 Abs. 1 lit. b DSGVO: Der DSBA überwacht die Einhaltung von Datenschutzrecht, internen Policies und Schulungsmaßnahmen. Er sammelt proaktiv Informationen, muss auf Verstöße aufmerksam machen, hat aber keine Weisungsmöglichkeiten. [E3/F38]

20.13 Rolle des DSBA bei PIA/DSFA

Die Folien erklären Art. 39 Abs. 1 lit. c DSGVO: Auf Anfrage berät und überwacht der DSBA bei Durchführung der PIA. Der Verantwortliche ist nach Art. 35 Abs. 2 DSGVO verpflichtet, die DSFA durchzuführen; nicht der DSBA. Der DSBA überwacht und berät nur. Es gibt keine allgemeine Beratungspflicht. Beratung betrifft etwa, ob eine PIA durchzuführen ist, welche Methodik zu wählen ist oder ob interne/externe Durchführung sinnvoll ist. Wenn der Verantwortliche dem Rat nicht folgt, ist dies zu begründen. [E3/F39]

20.14 Rolle im Konsultationsverfahren

Die Folien erklären die Rolle des DSBA im Konsultationsverfahren zu PIA nach Art. 36 DSGVO. Nach Art. 39 Abs. 1 lit. e DSGVO kann sich die Aufsichtsbehörde im Konsultationsverfahren an den DSBA wenden, weil er Sachkenntnis besitzt, insbesondere zu Verarbeitungs- und Organisationsprozessen. [E3/F40]

20.15 Haftung und Strafrisiken des DSBA

Die Folien sagen, dass der DSBA nach DSGVO/DSG keine strafrechtliche Verantwortung trägt. Es gibt aber mögliche zivil- bzw. arbeitsrechtliche Haftung gegenüber dem Verantwortlichen und strafrechtliche Haftung aufgrund möglicher Garantenstellung nach § 2 StGB. Genannt wird eine Entscheidung DSB-D550.705/2023. Alternative Haftungsgrundlagen sind arbeitsrechtliche Haftung nach DHG und zivilrechtliche Haftung nach § 1298 ABGB. Voraussetzungen sind Schaden, Kausalität, Rechtswidrigkeit und Verschulden. Haftungserleichterungen hängen vom Verschuldensgrad ab: entschuldbare Fehlleistung führt zu keiner Haftung; leichte Fahrlässigkeit kann auf Null reduziert werden; grobe Fahrlässigkeit kann gemildert werden; Vorsatz führt zu voller Haftung. [E3/F41-F42]

Bezug zur DSGVO: Die DSGVO legt die Compliance-Verantwortung primär beim Verantwortlichen bzw. Auftragsverarbeiter, vgl. Art. 24 DSGVO und Art. 38 Abs. 3 DSGVO; der DSB berät und überwacht nach Art. 39 DSGVO, ist aber nicht selbst die verantwortliche Stelle.

21. Praktische Erfahrungen als externer Datenschutzbeauftragter

21.1 Verankerung in der Organisation

Die Folien nennen als Einstieg die Verankerung in der Organisation. Fachabteilungen sollen Datenschutz „am Radar“ haben und rechtzeitig Kontakt aufnehmen. Akute Themen sind Betroffenenanfragen und Data Breaches. Geplante Änderungen betreffen z. B. Einführung neuer IT-Tools oder neuer Produkte. Der DSBA muss in Prozesse eingebunden werden, allen Mitarbeitern inklusive Kontaktmöglichkeiten bekannt gemacht werden, die wichtigsten Stakeholder kennenlernen und die Meldung an die Datenschutzbehörde darf nicht vergessen werden. [E3/F43-F44]

Bezug zur DSGVO: Diese organisatorische Einbindung entspricht Art. 38 Abs. 1 DSGVO, der frühzeitige und ordnungsgemäße Einbindung des DSBA in Datenschutzfragen verlangt.

21.2 Vorhandene Dokumentation prüfen

Die Folien nennen als Pflichtdokumentation: Verarbeitungsverzeichnis, Datenschutzerklärungen, Auftragsverarbeitervereinbarungen, Einwilligungserklärungen und gegebenenfalls Datenschutzfolgenabschätzungen. Diese Dokumente geben Überblick über Datenverarbeitungen. Weitere Dokumente können Richtlinien, Arbeitsanweisungen, Policies und Guidelines sein, z. B. für Betroffenenanfragen, Data Breaches und Sicherheitsmaßnahmen in bestimmten Bereichen. [E3/F45]

Bezug zur DSGVO: Verarbeitungsverzeichnis: Art. 30 DSGVO. Datenschutzerklärungen/ Informationspflichten: Art. 13 und 14 DSGVO. AVV: Art. 28 DSGVO. Einwilligung: Art. 7 DSGVO. DSFA: Art. 35 DSGVO. DataBreach-Prozesse: Art. 33 und 34 DSGVO.

21.3 Interne Abläufe kennenlernen

Die Folien empfehlen, konkrete Abläufe zu verstehen: Wer kennt die Datenverarbeitungen im Detail? Welche Datenkategorien, Empfänger, IT-Systeme und Auftragsverarbeiter gibt es? Gab es in der Vergangenheit Probleme? Außerdem sind Organisationsfragen relevant: Hat der Datenschutzbeauftragte zusätzliche Aufgaben wie Schulungen? Wer ist intern für Bereiche wie Marketing, Sales, HR oder IT zuständig? Wie ist die Zusammenarbeit mit der Rechtsabteilung, falls vorhanden? [E3/F46]

Bezug zur DSGVO: Diese Fragen dienen der wirksamen Erfüllung der Aufgaben nach Art. 39 DSGVO sowie der Einbindung nach Art. 38 DSGVO.

22. Abschlussfolien

Die Abschlussfolien nennen erneut Mag. Alexandra Ciarnau mit Telefonnummer und E-Mail-Adresse und bedanken sich für die Aufmerksamkeit. Zusätzlich werden DORDA-Rankings genannt: Legal500 2007-2025 Tier 1 TMT, Legal500 2020-2025 Tier 1 Data Privacy & Data Protection, Legal500 2021-2025 Tier 1 Intellectual Property und Chambers Europe 2008-2025 Band 1 TMT:IT. [E2/F35-F36, E3/F47-F48]

23. Kurzübersicht der wichtigsten DSGVO-Artikel aus den Folien

DSGVO-Norm	Thema	Wo in den Folien
Art. 1	Gegenstand und Ziele: Schutz natürlicher Personen + freier Datenverkehr	[E1/F4]
Art. 2	Sachlicher Anwendungsbereich, Haushaltsausnahme	[E1/F13–F14]
Art. 3	Räumlicher Anwendungsbereich, Marktortprinzip, Beobachtung	[E1/F10, E1/F13]
Art. 4 Nr. 1	Personenbezogene Daten	[E1/F14]
Art. 4 Nr. 2	Verarbeitung	[E1/F14]
Art. 4 Nr. 5	Pseudonymisierung	[E1/F21]
Art. 4 Nr. 7	Verantwortlicher	[E1/F17, E2/F21]
Art. 4 Nr. 8	Auftragsverarbeiter	[E1/F17, E2/F21]
Art. 4 Nr. 12	Verletzung des Schutzes personenbezogener Daten	[E3/F16]
Art. 4 Nr. 15	Gesundheitsdaten	[E1/F22]
Art. 5	Grundprinzipien und Rechenschaft	[E1/F24–F25, E2/F15–F16]
Art. 6	Rechtmäßigkeit / Rechtsgrundlagen	[E1/F25–F30]
Art. 7	Bedingungen für Einwilligung	[E1/F30–F32]
Art. 9	Besondere Kategorien personenbezogener Daten	[E1/F22, E1/F26]
Art. 10	Strafrechtliche Verurteilungen und Straftaten	[E1/F22]

Art. 24	Verantwortung des Verantwortlichen / Nachweis Compliance	[E2/F15–F16, E3/F3]
Art. 25	Privacy by Design and by Default	[E3/F3, E3/F5–F6]
Art. 26	Gemeinsame Verantwortlichkeit	[E1/F18, E2/F29–F30]
Art. 28	Auftragsverarbeiter, AVV, Subverarbeiter	[E2/F21–F27]
Art. 30	Verzeichnis der Verarbeitungstätigkeiten	[E2/F5–F8]
Art. 31	Zusammenarbeit mit Aufsichtsbehörde	[E2/F17]
Art. 32	Sicherheit der Verarbeitung / TOMs	[E2/F24, E3/F3, E3/F7–F9]
Art. 33	Meldung an Aufsichtsbehörde bei Data Breach	[E3/F18–F19, E3/F26]
Art. 34	Benachrichtigung der Betroffenen bei hohem Risiko	[E3/F18–F19]
Art. 35	Datenschutz-Folgenabschätzung / PIA	[E2/F9–F14, E3/F39]
Art. 36	Vorherige Konsultation bei nicht eindämbbarem hohem Risiko	[E3/F40]
Art. 37	Benennung Datenschutzbeauftragter	[E3/F29–F30]
Art. 38	Stellung Datenschutzbeauftragter	[E3/F31, E3/F35]
Art. 39	Aufgaben Datenschutzbeauftragter	[E3/F36–F40]
Art. 57 Abs. 3	Unentgeltlicher Kontakt mit Aufsichtsbehörde für DSBA	[E3/F36]
Art. 83	Geldbußen	[E1/F7, E3/F13]
Art. 89	Forschung, Statistik, Archivzwecke, Garantien	[E2/F32–F33]

24. Merksätze für die Prüfung

1. DSGVO prüfst du immer über Anwendungsbereich → Rollen → Datenkategorie → Zweck → Rechtsgrundlage → Pflichten/TOMs. Das entspricht den Folienfragen: Wer verarbeitet welche Daten von wem zu welchem Zweck? [E1/F16]
2. Pseudonym heißt nicht anonym. Pseudonymisierte Daten bleiben personenbezogen, solange eine Zuordnung mit Zusatzinformationen möglich ist. [E1/F21; Art. 4 Nr. 5 DSGVO; Erwägungsgrund 26 DSGVO]
3. Art. 6 reicht bei sensiblen Daten nicht allein. Bei Art.-9-Daten braucht man zusätzlich eine Ausnahme nach Art. 9 Abs. 2 DSGVO. [E1/F22, E1/F26]

4. Einwilligung ist nur gut, wenn sie wirklich freiwillig, informiert, aktiv und nachweisbar ist. Vorangekreuzte Kästchen, Schweigen oder bloße Visitenkartenübergabe reichen nicht. [E1/F30-F32; Art. 7 DSGVO; Erwägungsgrund 32 DSGVO]
5. Berechtigtes Interesse ist nie automatisch. Es braucht immer eine Abwägung: Datenumfang, Risiko, Erwartbarkeit und Schutzbedürftigkeit. [E1/F28-F29; Art. 6 Abs. 1 lit. f DSGVO]
6. AVV ist nicht nur Formalität. Verantwortliche müssen geeignete Auftragsverarbeiter auswählen, Verträge schließen, Subverarbeiter kontrollieren und Audit-/Informationsrechte sichern. [E2/F21-F27; Art. 28 DSGVO]
7. DSFA braucht man bei hohem Risiko, nicht bei jedem Projekt. Aber wenn hohes Risiko vorliegt, muss sie vorab erfolgen und dokumentiert werden. [E2/F9-F14; Art. 35 DSGVO]
8. Data Breach = Risikoentscheidung unter Zeitdruck. Binnen 72 Stunden ab Kenntnis muss bewertet werden, ob gemeldet werden muss; alle Vorfälle sind intern zu dokumentieren. [E3/F16-F19; Art. 33-34 DSGVO]
9. TOMs sind dynamisch. Sie müssen regelmäßig überprüft werden und hängen von Stand der Technik, Kosten, Verarbeitung und Risiko ab. [E3/F3-F9; Art. 24, 25, 32 DSGVO]
10. Der Datenschutzbeauftragte berät und überwacht, aber er ist nicht der Verantwortliche und nicht die Behörde. Verantwortlich bleibt die Organisation. [E3/F28-F40; Art. 37-39 DSGVO]